

AI-Powered Phishing Awareness & Training Platform

Developer Guide

Version 1.0

Hawkins Cookers Limited

July 2026

Version	Date	Changes	Author
1.0	15 Jul 2026	Initial Release	Subhrojyoti

Document Control

Item	Details
Project Name	AI-Powered Phishing Awareness & Training Platform
Organization	Hawkins Cookers Limited
Technology	Python, Flask, PostgreSQL, Gemini AI
Database	PostgreSQL
Frontend	HTML, CSS, JavaScript
Backend	Flask
AI Engine	Google Gemini
Document Type	Developer Guide
Audience	Developers, Software Engineers, System Administrators
Version	1.0
Status	Production Release

AI-Powered Phishing Awareness & Training Platform.....	1
Developer Guide.....	1
Document Control.....	2
1. Introduction.....	14
Purpose of the Project.....	14
2. Project Overview.....	15
Business Problem.....	15
Solution Overview.....	15
3. System Objectives.....	16
4. High Level System Architecture.....	16
5. Complete Workflow.....	17
Step 1 – Administrator Login.....	17
Step 2 – Employee Selection.....	17
Step 3 – Threat Scenario Selection.....	17
Step 4 – AI Prompt Construction.....	17
Step 5 – AI Email Generation.....	18
Step 6 – Campaign Validation.....	18

Step 7 – Campaign Storage.....	18
Step 8 – Email Delivery.....	18
Step 9 – Employee Interaction Tracking.....	18
Step 10 – Risk Assessment.....	18
Step 11 – Dashboard Update.....	19
6. Project Folder Structure.....	19
7. Main Application (app.py).....	21
Overview.....	21
Primary Responsibilities.....	21
Application Initialization.....	21
Encryption System.....	21
Database Configuration.....	22
Artificial Intelligence Configuration.....	22
AI Response Processing.....	22
1. sanitize_ai_subject().....	23
2. sanitize_ai_body().....	23
3. parse_ai_response().....	23
Corporate Email Identity.....	23
Threat Intelligence Database.....	24
Employee Management Functions.....	24
8. Campaign Management Layer.....	24
Overview.....	24
Campaign Lifecycle.....	24
Campaign Creation.....	26
Function: create_campaign_run().....	26
Purpose.....	26
Why is this needed?.....	26
Input Parameters.....	26
Internal Working.....	26
Employee Registration inside Campaign.....	27
Function: create_campaign_target().....	27
Purpose.....	27
Information Stored.....	27
Why is this important?.....	27
Updating Campaign Status.....	28
Function: update_campaign_target_status().....	28
Purpose.....	28
Example.....	28
Prompt History Management.....	29
Function: get_latest_prompt_history_for_employee().....	29
Purpose.....	29
Information Retrieved.....	29
Why?.....	30
Secure Prompt Decryption.....	30
Function: decrypt_prompt_history_payload().....	30
Purpose.....	30
Why Encryption?.....	30
Previous Subject Retrieval.....	31
Function: get_previous_subjects_for_employee().....	31
Purpose.....	31

Why?.....	31
Previous CTA Retrieval.....	31
Function: get_previous_ctas_for_employee().....	31
Purpose.....	31
Prompt Payload Collection.....	32
Function: get_all_prompt_payloads_for_employee().....	32
Purpose.....	32
Previously Used Scenarios.....	32
Function: get_used_scenario_ids_for_employee().....	32
Purpose.....	32
Example.....	32
Campaign Attempt Counter.....	33
Function: get_real_attempt_count_for_employee().....	33
Purpose.....	33
Organization-wide Learning.....	34
Function: get_winning_scenarios_org_wide().....	34
Purpose.....	34
9. Artificial Intelligence Email Evolution Engine.....	34
Overview.....	34
AI Generation Workflow.....	34
Design Philosophy.....	35
Threat Scenario Library.....	36
Human Resources.....	36
Finance.....	37
Information Technology.....	37
Cyber Security.....	37
Management.....	37
Scenario Selection.....	37
Function: select_next_scenario().....	37
Purpose.....	37
Selection Strategy.....	37
Rule 1.....	37
Rule 2.....	38
Rule 3.....	38
Rule 4.....	38
Sender Identity Resolution.....	38
Function: resolve_sender_identity().....	38
Prompt Construction.....	39
Function: build_prompt().....	39
Employee Information.....	39
Campaign Context.....	39
Memory.....	39
Organizational Intelligence.....	40
Tone Control.....	40
Gemini Email Generation.....	40
Campaign Validation.....	41
Campaign Memory.....	41
Outcome.....	41
10. Campaign Quality Engine & Campaign Validation.....	42
Overview.....	42

Why is a Validation Engine Required?.....	42
Campaign 1.....	42
Campaign 2.....	42
Validation Workflow.....	43
Campaign Quality Engine.....	44
Purpose.....	44
Validation Rules.....	44
Rule 1 – Subject Validation.....	44
Purpose.....	44
Why?.....	45
Example.....	45
Rule 2 – Email Body Validation.....	45
Purpose.....	45
Why?.....	45
Example.....	46
Rule 3 – Call-To-Action Validation.....	46
Purpose.....	46
Example.....	46
Rule 4 – Sender Validation.....	47
Purpose.....	47
Why?.....	47
Rule 5 – Scenario Validation.....	47
Purpose.....	47
Example.....	48
Similarity Detection.....	48
Sequence Similarity.....	48
Jaccard Similarity.....	49
Combined Similarity.....	49
Similarity Thresholds.....	49
AI Regeneration.....	50
Validation Report.....	50
Benefits of the Validation Engine.....	51
Chapter Summary.....	51
11. Risk Assessment Engine.....	51
Overview.....	51
Why is a Risk Engine Required?.....	52
Risk Calculation Workflow.....	53
Event Types.....	54
Event Weighting.....	54
Formula 1 – Base Event Score.....	55
Example.....	55
Formula 2 – Repeat Behaviour Penalty.....	55
Formula 3 – Role Weighting.....	56
Formula 4 – Department Weighting.....	56
Formula 5 – Positive Behaviour Rewards.....	57
Formula 6 – Risk Normalization.....	57
Risk Classification.....	57
Employee Ranking.....	58
Risk Percentile.....	58
Department Risk Calculation.....	59

Risk Breakdown.....	59
Dashboard Integration.....	59
Benefits of the Risk Assessment Engine.....	60
Chapter Summary.....	60
12. Event Tracking and Monitoring System.....	60
Overview.....	60
Why Event Tracking is Required.....	61
Event Tracking Workflow.....	61
Event Types.....	62
Secure Event Logging.....	63
Function: secure_log_event().....	63
Purpose.....	63
Information Stored.....	63
Payload Types.....	64
Risk Contribution.....	64
Retrieving Event History.....	65
Function: get_all_logged_events().....	65
Purpose.....	65
Internal Working.....	65
Employee Event History.....	65
Function: get_user_event_history().....	65
Purpose.....	65
Example.....	65
Target Achievement Detection.....	66
Function: is_target_achieved().....	66
Purpose.....	66
Previous Campaign Result.....	66
Function: get_previous_result_for_user().....	67
Purpose.....	67
Identifying Caught Employees.....	67
Function: get_caught_users().....	67
Purpose.....	67
Dashboard Integration.....	68
Security Features.....	68
Encryption.....	68
Audit Trail.....	68
Integrity.....	68
Confidentiality.....	68
Benefits of the Event Tracking System.....	69
Chapter Summary.....	69
13. Email Delivery System.....	69
Overview.....	69
Why an Email Delivery System is Required.....	70
Email Delivery Workflow.....	70
Email Components.....	71
Sender Identity Selection.....	71
Corporate Signature Generation.....	72
Function: get_email_signature().....	72
Purpose.....	72
Corporate Legal Disclaimer.....	73

Dynamic Call-To-Action Generation.....	73
Tracking Link Generation.....	73
Link-Based Campaigns.....	73
Credential-Based Campaigns.....	74
Tracking Pixel.....	74
HTML Email Assembly.....	74
SMTP Delivery.....	75
Function: send_simulation_email().....	75
Purpose.....	75
Internal Process.....	75
Email Personalization.....	76
Security Considerations.....	76
Personalized Tracking.....	76
Controlled Delivery.....	76
Auditability.....	76
Benefits of the Email Delivery System.....	77
Chapter Summary.....	77
14. Security Architecture.....	77
Overview.....	77
Security Architecture Overview.....	78
Data Encryption.....	78
Purpose.....	79
Information Protected by Encryption.....	79
Prompt Encryption.....	79
Purpose.....	79
Secure Event Storage.....	80
Administrator Authentication.....	80
Brute Force Protection.....	81
Purpose.....	81
Login Attempt Database.....	81
Automatic Lock Release.....	81
Security Alert Notifications.....	82
Administrator Login Alert.....	82
Brute Force Attack Alert.....	82
Campaign Integrity.....	82
Audit Trail.....	83
Database Protection.....	83
AI Safety Controls.....	84
Security Benefits.....	84
Chapter Summary.....	85
15. Administrator Dashboard.....	85
Overview.....	85
Purpose of the Dashboard.....	85
Dashboard Workflow.....	86
Dashboard Components.....	86
Employee Management Panel.....	87
Purpose.....	87
Campaign Monitoring Panel.....	87
Purpose.....	87
Employee Status Monitoring.....	88

Risk Dashboard.....	88
Purpose.....	88
Department Risk Panel.....	89
Campaign Analytics.....	89
AI Recommendation Panel.....	90
Security Activity Feed.....	90
Enterprise Risk Summary.....	91
Platform Health Monitoring.....	91
Real-Time Updates.....	91
Benefits of the Dashboard.....	92
Chapter Summary.....	92
Chapter 16: Flask Routes and API Documentation.....	92
16.1 Overview.....	92
Purpose of Flask Routes.....	93
Route Processing Workflow.....	94
HTTP Methods Used.....	94
GET.....	94
POST.....	95
Route Categories.....	95
1. Authentication Routes.....	95
2. Campaign Management Routes.....	96
3. Employee Interaction Routes.....	96
4. Dashboard Routes.....	96
5. Report Routes.....	97
6. AI Routes.....	97
7. Security Routes.....	97
General Route Lifecycle.....	97
Step 2.....	98
Step 3.....	98
Step 4.....	98
Step 5.....	98
Step 6.....	98
Step 7.....	98
Step 8.....	98
Error Handling.....	99
Relationship with Other Modules.....	99
Chapter Summary.....	100
16.2 Authentication Routes.....	100
Overview.....	100
Authentication Workflow.....	100
Route 1 – Administrator Login Page.....	101
Route.....	101
HTTP Method.....	101
Purpose.....	101
Processing Steps.....	102
Database Access.....	102
Output.....	102
Route 2 – Administrator Login.....	102
Route.....	102
HTTP Method.....	102

Purpose.....	102
Input Parameters.....	103
Processing Steps.....	103
Step 1.....	103
Step 2.....	103
Step 3.....	103
Step 4.....	103
Step 5.....	104
Modules Used.....	104
Database Tables Used.....	104
Output.....	104
Brute Force Protection.....	105
Failed Login Handling.....	105
Successful Login Handling.....	105
Administrator Login Notification.....	106
Account Lock Notification.....	106
Session Management.....	107
Security Features.....	107
Credential Verification.....	107
Brute Force Protection.....	107
Automatic Account Locking.....	107
Login Notifications.....	108
Session Security.....	108
Audit Logging.....	108
Error Conditions.....	108
Chapter Summary.....	108
16.3 Dashboard Routes.....	108
Overview.....	108
Dashboard Workflow.....	109
Route 1 – Dashboard Home.....	110
Route.....	110
HTTP Method.....	110
Purpose.....	110
Processing Steps.....	111
Step 1.....	111
Step 2.....	111
Step 3.....	111
Step 4.....	111
Step 5.....	111
Step 6.....	111
Step 7.....	111
Step 8.....	111
Information Displayed.....	112
Database Tables Used.....	112
Output.....	112
Route 2 – Employee Dashboard.....	112
Purpose.....	112
Employee Status Calculation.....	113
Route 3 – Campaign Dashboard.....	113
Purpose.....	113

Campaign Status.....	114
Route 4 – Employee Risk Dashboard.....	115
Purpose.....	115
Route 5 – Department Analytics.....	115
Purpose.....	115
Route 6 – AI Recommendation Dashboard.....	116
Purpose.....	116
Route 7 – Security Activity Feed.....	116
Purpose.....	116
Route 8 – System Health Dashboard.....	117
Purpose.....	117
Dynamic Dashboard Updates.....	117
Data Sources.....	118
Error Handling.....	118
Benefits of Dashboard Routes.....	119
Chapter Summary.....	119
16.4 Campaign Management Routes.....	119
Overview.....	119
Campaign Processing Workflow.....	120
Purpose of Campaign Routes.....	121
Route 1 – Create Campaign.....	121
Route.....	121
HTTP Method.....	122
Purpose.....	122
Input Parameters.....	122
Processing Steps.....	122
Step 1.....	122
Step 2.....	122
Step 3.....	122
Step 4.....	123
Step 5.....	123
Route 2 – Employee Selection.....	123
Purpose.....	123
Information Stored.....	123
Route 3 – Retrieve Campaign History.....	124
Purpose.....	124
Route 4 – Threat Scenario Selection.....	124
Purpose.....	124
Route 5 – AI Prompt Generation.....	125
Purpose.....	125
Route 6 – AI Email Generation.....	126
Purpose.....	126
Route 7 – Campaign Validation.....	126
Purpose.....	126
Route 8 – Campaign Encryption.....	127
Purpose.....	127
Route 9 – Email Delivery.....	127
Purpose.....	127
Step 1.....	128
Step 2.....	128

Step 3.....	128
Step 4.....	128
Step 5.....	128
Step 6.....	128
Step 7.....	128
Route 10 – Campaign Monitoring.....	129
Purpose.....	129
Route 11 – Campaign Completion.....	129
Purpose.....	129
Database Tables Used.....	129
Error Handling.....	130
Security Controls.....	130
Encryption.....	131
Validation.....	131
Audit Trail.....	131
Prompt History.....	131
Employee Isolation.....	131
Benefits of Campaign Management Routes.....	131
Chapter Summary.....	132
16.5 Employee Interaction & Tracking Routes.....	132
Overview.....	132
Interaction Workflow.....	132
Purpose of Interaction Routes.....	133
Route 1 – Email Open Tracking.....	134
Route.....	134
HTTP Method.....	134
Purpose.....	134
Processing Steps.....	134
Step 1.....	134
Step 2.....	134
Step 3.....	134
Step 4.....	135
Step 5.....	135
Event Generated.....	135
Route 2 – Link Click Tracking.....	135
Route.....	135
HTTP Method.....	135
Purpose.....	135
Processing Steps.....	136
Step 1.....	136
Step 2.....	136
Step 3.....	136
Step 4.....	136
Step 5.....	136
Event Generated.....	136
Route 3 – Simulated Login Page.....	136
Route.....	136
HTTP Method.....	137
Purpose.....	137
Information Displayed.....	137

Route 4 – Credential Submission.....	138
Route.....	138
HTTP Method.....	138
Purpose.....	138
Processing Steps.....	138
Step 1.....	138
Step 2.....	138
Step 3.....	138
Step 4.....	139
Step 5.....	139
Step 6.....	139
Step 7.....	139
Event Generated.....	139
Route 5 – Event Logging.....	139
Purpose.....	139
Route 6 – Campaign Status Update.....	140
Route 7 – Risk Engine Trigger.....	140
Route 8 – Dashboard Refresh.....	141
Database Tables Used.....	141
Security Controls.....	142
Encrypted Event Storage.....	142
Campaign Validation.....	142
Audit Trail.....	142
Personalized Tracking.....	142
Controlled Risk Updates.....	142
Error Handling.....	142
Benefits of Employee Interaction Routes.....	143
Chapter Summary.....	143
16.6 Reporting Routes.....	143
Overview.....	143
Reporting Workflow.....	144
Purpose of Reporting Routes.....	145
Route 1 – Campaign Report.....	145
Route.....	145
HTTP Method.....	145
Purpose.....	145
Information Included.....	146
Route 2 – Employee Risk Report.....	146
Purpose.....	146
Route 3 – Department Risk Report.....	146
Purpose.....	146
Route 4 – Organizational Security Summary.....	147
Purpose.....	147
Route 5 – Employee Behaviour Report.....	148
Purpose.....	148
Route 6 – Campaign History Report.....	148
Purpose.....	148
Report Generation Process.....	149
Step 1.....	149
Step 2.....	149

Step 3.....	149
Step 4.....	149
Step 5.....	149
Step 6.....	149
Step 7.....	149
Data Sources.....	150
Report Calculations.....	150
Campaign Success Rate.....	150
Department Average Risk.....	151
Employee Ranking.....	151
Organizational Risk.....	151
Security Controls.....	151
Administrator Authentication.....	151
Read-Only Access.....	151
Encrypted Data Processing.....	151
Auditability.....	151
Error Handling.....	152
Benefits of Reporting Routes.....	152
Chapter Summary.....	152
16.7 System Health & Administrative Utility Routes.....	153
Overview.....	153
Purpose of System Health Routes.....	153
System Health Workflow.....	153
Route 1 – System Health Dashboard.....	154
Route.....	154
HTTP Method.....	154
Purpose.....	155
Components Monitored.....	155
Health Status Levels.....	155
Route 2 – Database Health Check.....	155
Purpose.....	155
Validation Steps.....	156
Information Displayed.....	156
Route 3 – AI Service Health.....	156
Purpose.....	156
Validation.....	156
Route 4 – SMTP Health Check.....	157
Purpose.....	157
Route 5 – Event Tracking Health.....	157
Purpose.....	157
Route 6 – Risk Engine Health.....	158
Purpose.....	158
Route 7 – Administrative Utility Functions.....	158
Platform Diagnostics.....	158
Automatic Health Monitoring.....	159
Error Handling.....	159
Security Considerations.....	160
Administrator Access.....	160
Read-Only Diagnostics.....	160
Controlled Visibility.....	160

Audit Logging.....	160
Benefits of the System Health Module.....	160
Chapter Summary.....	161
17. Developer Maintenance Guide.....	161
18. Installation and Deployment Guide.....	163
19. Troubleshooting and Maintenance Guide.....	165
20. Conclusion.....	168
Appendix.....	169

1. Introduction

Purpose of the Project

The AI-Powered Phishing Awareness & Training Platform is an enterprise cybersecurity awareness solution developed for Hawkins Cookers Limited. The platform simulates realistic phishing attacks against employees to measure their security awareness, identify vulnerable users, calculate organizational cyber risk, and recommend targeted security improvements.

Unlike traditional phishing simulation tools that repeatedly send similar emails, this platform uses Artificial Intelligence to generate unique phishing emails for every campaign. It continuously learns from previous campaigns, avoids repetition, selects different attack scenarios, and evolves future phishing simulations based on employee behavior.

The platform provides administrators with a centralized dashboard for campaign management, employee risk monitoring, campaign analytics, phishing success tracking, and security reporting.

2. Project Overview

Business Problem

Many organizations conduct cybersecurity awareness training by sending the same phishing emails repeatedly. Employees eventually recognize these emails, making the training ineffective and producing inaccurate security awareness measurements.

The major challenges identified were:

- Employees receive repetitive phishing emails.
- Email subjects become predictable.
- Attack scenarios are reused frequently.
- Security teams cannot accurately measure employee awareness.
- No centralized employee risk calculation exists.
- No mechanism exists to evolve phishing campaigns based on previous campaign performance.
- Organizations cannot identify departments with the highest phishing susceptibility.

This project addresses these limitations by introducing AI-driven phishing simulations that continuously evolve and adapt.

Solution Overview

The platform automates the complete phishing awareness lifecycle.

The administrator selects employees for a phishing campaign. The system retrieves employee information from the database, identifies the employee's department, reviews previous phishing history, analyzes prior campaign performance, and selects an appropriate phishing scenario.

The AI Engine generates a completely new phishing email based on the selected scenario while ensuring that previous subjects, email content, sender identities, and call-to-action messages are not repeated.

Before sending the email, the Campaign Validation Engine verifies that the generated campaign satisfies organizational quality requirements. If the campaign fails validation, the AI regenerates the email until all quality checks pass.

Once approved, the email is delivered to the employee. Every interaction, including email opening, image loading, link clicking, or credential submission, is securely logged. These interactions are later processed by the Risk Engine to calculate employee risk scores and update dashboard analytics.

3. System Objectives

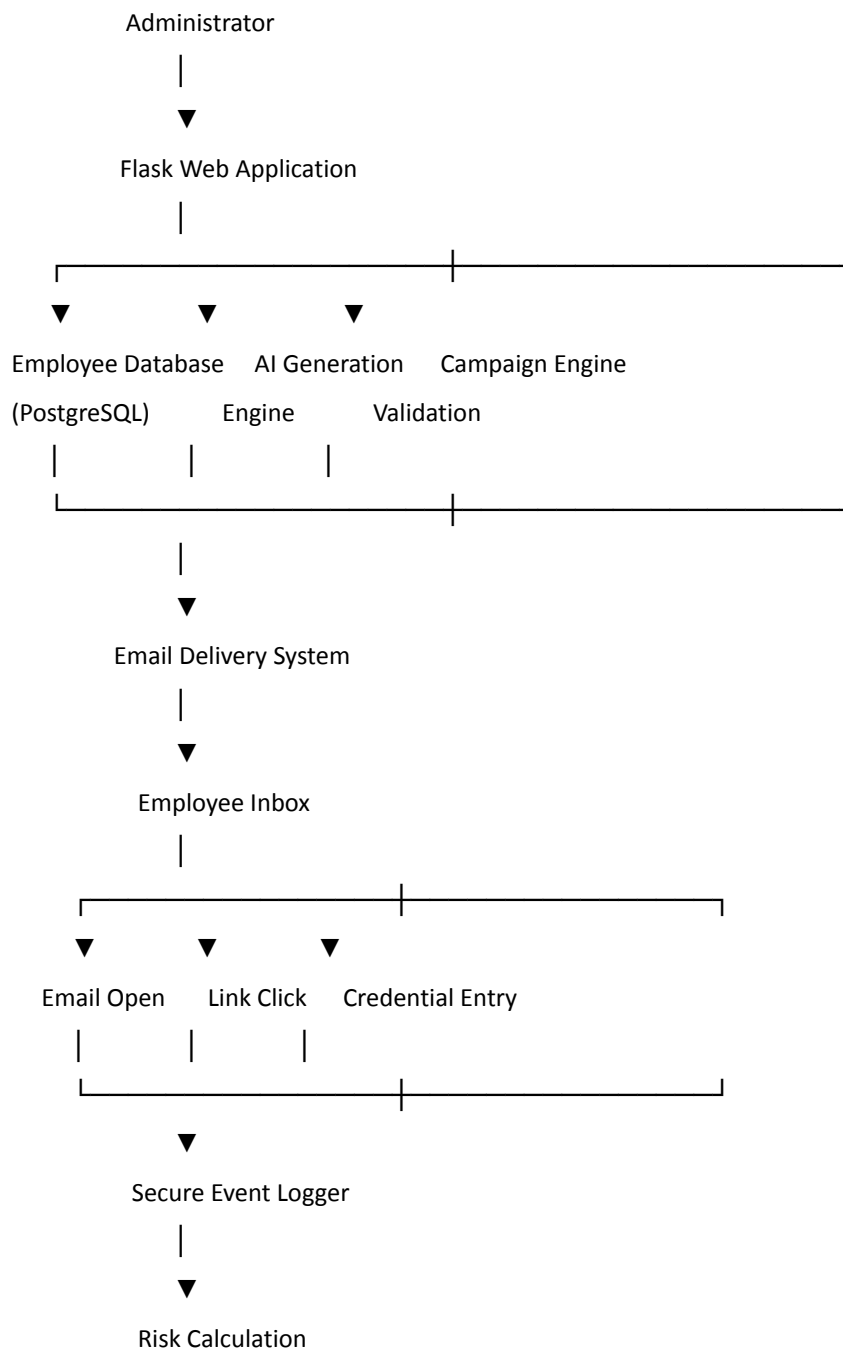
The platform has been designed to achieve the following objectives:

- Generate realistic AI-powered phishing emails.
- Avoid repetition across multiple phishing campaigns.
- Track employee interactions with phishing emails.
- Capture phishing simulation events securely.

- Calculate employee cybersecurity risk.
 - Rank employees according to phishing susceptibility.
 - Measure department-level cybersecurity posture.
 - Provide administrators with real-time dashboards.
 - Generate security recommendations.
 - Maintain encrypted campaign history.
 - Protect administrator accounts against brute-force attacks.
-

4. High Level System Architecture

The platform consists of multiple independent modules that work together to perform phishing simulations.





5. Complete Workflow

The platform follows a structured sequence of operations.

Step 1 – Administrator Login

The administrator logs into the management dashboard. Before access is granted, the system verifies administrator credentials and checks whether the account has been temporarily locked due to excessive failed login attempts. Successful logins trigger an administrative security notification.

Step 2 – Employee Selection

The administrator selects one or more employees from the employee database. Employee information such as department, designation, target objective, and previous campaign history is retrieved from PostgreSQL.

Step 3 – Threat Scenario Selection

Based on the employee's department, the system selects an appropriate phishing scenario from the Threat Scenario Library. The selection process ensures that previously used scenarios are avoided whenever possible.

Step 4 – AI Prompt Construction

The Email Evolution Engine constructs a detailed prompt for the AI model. The prompt includes employee context, department-specific information, previous campaign outcomes, historical subjects, historical call-to-action phrases, previously used scenarios, and campaign strategy. This context guides the AI to generate a realistic yet unique phishing email.

Step 5 – AI Email Generation

Google Gemini generates a phishing email consisting of a subject line and email body. The response is cleaned and formatted before further processing.

Step 6 – Campaign Validation

The Campaign Validation Engine evaluates the generated email by checking subject similarity, body similarity, call-to-action uniqueness, sender diversity, and scenario reuse. If any validation rule fails, regeneration instructions are sent back to the AI until a valid campaign is produced.

Step 7 – Campaign Storage

Once validated, the campaign details are encrypted and stored in the database. This preserves a secure history of prompts, generated emails, selected scenarios, and campaign metadata.

Step 8 – Email Delivery

The phishing email is delivered using the SMTP mail server. Tracking URLs and tracking images are embedded into the email to monitor employee interactions.

Step 9 – Employee Interaction Tracking

When an employee opens the email, loads embedded images, clicks phishing links, or submits credentials, the platform records these events securely. Each event is encrypted before storage.

Step 10 – Risk Assessment

Captured events are processed by the Risk Engine. Employee behavior is converted into numerical risk scores, normalized, classified into predefined risk categories, and stored for reporting.

Step 11 – Dashboard Update

The administrative dashboard automatically reflects updated campaign statistics, employee risk levels, department risk scores, phishing success rates, and organizational cybersecurity metrics.

6. Project Folder Structure

The project has been designed using a modular architecture. Instead of placing all logic inside a single file, every major functionality has been separated into independent modules. This approach improves readability, simplifies maintenance, reduces code duplication, and allows developers to modify one component without affecting the rest of the application.

Each module is responsible for performing a specific task, while the main application (`app.py`) acts as the central controller that coordinates communication between all modules.

A typical project structure is shown below.

```
AI-Phishing-Awareness-Platform/  
|  
├─ app.py  
├─ admin_alert_service.py  
├─ bruteforce_service.py  
├─ email_evolution_engine.py  
├─ campaign_quality_engine.py  
├─ campaign_validator.py  
├─ risk_engine.py  
├─ risk_calculator.py  
├─ risk_classifier.py  
├─ department_risk.py  
├─ threat_scenarios.py  
├─ engine.py  
├─ secret.key  
├─ requirements.txt  
├─ templates/  
├─ static/  
├─ system_health/  
├─ database/  
└─ README.md
```

The following sections explain the purpose of each file.

File	Purpose
app.py	Main application responsible for coordinating all platform activities.

admin_alert_service.py	Sends administrator login alerts and brute-force attack notifications through email.
bruteforce_service.py	Protects administrator accounts against repeated failed login attempts.
email_evolution_engine.py	Generates intelligent phishing emails using AI while ensuring every campaign remains unique.
campaign_quality_engine.py	Performs quality assurance on AI-generated phishing campaigns before delivery.
campaign_validator.py	Checks similarity between previous and newly generated phishing emails.
risk_engine.py	Calculates employee risk scores and updates organizational risk information.
risk_calculator.py	Contains mathematical formulas used for risk computation.
risk_classifier.py	Converts numerical scores into predefined organizational risk levels.
department_risk.py	Calculates overall cybersecurity risk for each department.
threat_scenarios.py	Stores phishing scenarios categorized by department.
engine.py	Supports baseline email delivery and testing utilities.
templates/	Contains all HTML pages displayed to users and administrators.
static/	Stores CSS, JavaScript, icons, and images used by the web interface.
system_health/	Performs platform health monitoring and service status checks.

7. Main Application (app.py)

Overview

The `app.py` file is the central component of the platform. It acts as the main controller that initializes the application, establishes database connections, configures encryption, integrates Artificial Intelligence, processes user requests,

manages phishing campaigns, records employee interactions, calculates cybersecurity risk, and serves the administrator dashboard.

Every major module communicates through this file. It receives requests from users, invokes the appropriate business logic, interacts with the database, and returns the required response.

In simple terms, `app.py` functions as the "brain" of the application.

Primary Responsibilities

The responsibilities of `app.py` include:

- Starting the Flask web application.
 - Initializing application security.
 - Connecting to the PostgreSQL database.
 - Loading AI configuration.
 - Managing phishing campaigns.
 - Sending phishing simulation emails.
 - Recording employee interactions.
 - Encrypting sensitive campaign information.
 - Generating employee risk information.
 - Supporting administrator authentication.
 - Providing dashboard data through web routes.
 - Coordinating communication between all supporting modules.
-

Application Initialization

The application begins by importing all required libraries and initializing the Flask framework. A unique secret key is generated to protect user sessions and prevent unauthorized session manipulation. The application also loads supporting modules responsible for campaign validation, risk calculation, administrator security alerts, brute-force protection, and system health monitoring.

Encryption System

Before any sensitive information is stored, the application checks whether an encryption key already exists. If the key is missing, a new key is automatically generated. The same key is then loaded into memory and used by the encryption engine throughout the application.

This encryption system protects confidential information such as AI prompts, generated phishing campaigns, employee interaction records, and simulation data before they are written into the database.

Database Configuration

The application stores all operational information inside a PostgreSQL database.

Whenever employee records, campaign information, event logs, or dashboard statistics are required, the application establishes a database connection using a dedicated helper function. This approach ensures that all modules use a consistent connection method and simplifies future database maintenance.

Artificial Intelligence Configuration

The platform integrates Google Gemini to generate phishing emails.

The AI configuration stores the API key required to communicate with the Gemini service. When a phishing campaign is initiated, the Email Evolution Engine constructs a detailed prompt and submits it to Gemini. The AI-generated subject and email body are returned to the application for further validation and processing.

AI Response Processing

Large Language Models may return responses in slightly different formats. To ensure consistency, the application cleans every AI response before using it.

Three helper functions perform this task:

1. `sanitize_ai_subject()`

This function cleans the generated email subject.

It removes unnecessary prefixes such as "Subject:", deletes markdown formatting characters, removes redundant whitespace, and guarantees that a valid subject line is always available.

If the AI fails to produce a subject, a default subject is automatically assigned.

2. sanitize_ai_body()

This function prepares the email body for delivery.

It removes markdown symbols, converts paragraphs into HTML, preserves spacing, and formats the email so that it displays correctly in email clients.

If the AI produces an empty response, a default message is inserted automatically.

3. parse_ai_response()

Gemini may return the subject and body in multiple formats. This function detects the response format, separates the subject from the body, cleans both components, and returns standardized output.

As a result, downstream modules always receive a consistent subject line and HTML body regardless of the AI's original formatting.

Corporate Email Identity

To improve realism, the platform does not send every phishing email from the same fictional sender.

Instead, it maintains department-specific sender identities and signatures. Depending on the selected phishing scenario, the email may appear to originate from Human Resources, Finance, Information Technology, the Security Operations Center, or Executive Management.

This variation increases realism and prevents employees from recognizing repeated sender patterns across multiple campaigns.

Threat Intelligence Database

The application contains an internal repository of department-specific phishing templates.

Each department maintains its own collection of realistic business scenarios, including payroll notifications, vendor payments, password expiration notices, emergency security alerts, and executive requests.

Every scenario defines:

- Threat actor
- Attack scenario
- Email subject
- Email body
- Payload type

This information serves as the foundation for AI prompt generation. Rather than creating emails entirely from scratch, the AI receives structured business context that results in more realistic and organization-specific phishing simulations.

Employee Management Functions

The application includes helper functions responsible for retrieving employee information from the database.

These functions allow the platform to search employees using either their email address or internal employee identifier. The retrieved information is used throughout the campaign generation, risk calculation, dashboard reporting, and event logging processes.

By centralizing employee retrieval logic, all modules access employee information through a consistent interface, reducing duplicated database queries and simplifying future maintenance.

8. Campaign Management Layer

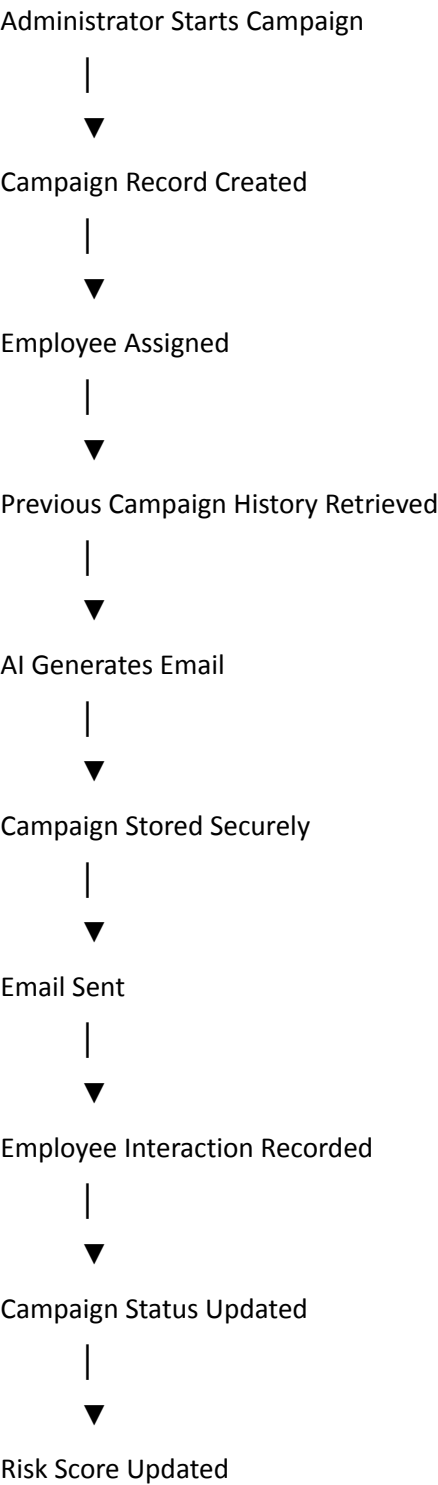
Overview

The Campaign Management Layer controls the complete lifecycle of a phishing simulation campaign. It is responsible for creating campaigns, assigning employees, maintaining campaign history, encrypting AI-generated content, tracking employee progress, and recording campaign outcomes.

Rather than sending emails directly, the platform first creates a structured campaign record. Every phishing email generated by the system belongs to a specific campaign. This design makes it possible to monitor campaign performance, measure employee behavior, generate reports, and maintain a complete audit trail of all phishing simulations.

Campaign Lifecycle

Every phishing campaign follows the sequence shown below.



Campaign Creation

Function: `create_campaign_run()`

Purpose

This function creates a new phishing campaign inside the database.

A campaign acts as a container that groups all employees participating in the same phishing exercise. Instead of storing emails individually, every generated email is linked to a campaign identifier.

Why is this needed?

Imagine 200 employees receive phishing emails.

Without campaign IDs, there would be no way to determine:

- which employees belonged to Campaign A
- which belonged to Campaign B
- campaign success rate
- campaign completion status
- campaign reports

This function solves that problem.

Input Parameters

Parameter	Description
campaign_name	Name assigned to the phishing campaign
trigger_mode	Indicates whether the campaign was started manually or automatically
notes	Additional campaign information

Internal Working

When called, the function:

1. Connects to PostgreSQL.
2. Inserts a new record into the `campaign_runs` table.
3. Generates a unique campaign identifier.
4. Saves campaign information.
5. Returns the campaign ID to the application.

That campaign ID is used throughout the remainder of the phishing simulation.

Employee Registration inside Campaign

Function: `create_campaign_target()`

Purpose

Once a campaign exists, every employee selected by the administrator must be attached to that campaign.

This function creates that relationship.

Information Stored

For every employee, the platform stores:

- Campaign ID
 - Employee ID
 - Employee Name
 - Email Address
 - Department
 - Target Goal
 - Current Status
 - Attempt Number
 - Completion Status
-

Why is this important?

Instead of simply sending emails,

the platform knows:

- which employee belongs to which campaign
- how many attempts have been made
- whether the employee completed the objective
- whether additional phishing simulations are required

This enables long-term campaign tracking.

Updating Campaign Status

Function: `update_campaign_target_status()`

Purpose

As employees interact with phishing emails, their campaign status changes.

For example:

TRIGGERED

↓

EMAIL OPENED

↓

LINK CLICKED

↓

CREDENTIAL SUBMITTED

↓

ACHIEVED

This function updates those changes inside the database.

Example

Suppose an employee submits credentials.

The function immediately updates:

Status = COMPLETED

Achieved = TRUE

Achievement Time = Current Timestamp

This information later appears in reports and dashboards.

Prompt History Management

One of the most intelligent components of this platform is its ability to remember previous phishing campaigns.

Instead of generating random emails every time, the AI learns what has already been used.

This prevents repetition.

Function: `get_latest_prompt_history_for_employee()`

Purpose

Retrieves the most recent phishing campaign delivered to a specific employee.

Information Retrieved

- Previous AI prompt
 - Previous campaign ID
 - Previous scenario
 - Previous email
 - Previous AI response
-

Why?

The Email Evolution Engine needs to know:

"What did we send last time?"

Only then can it create a completely different phishing email.

Secure Prompt Decryption

Function: `decrypt_prompt_history_payload()`

Purpose

The platform never stores AI prompts as plain text.

Instead,

every generated prompt is encrypted before storage.

When historical information is needed, this function decrypts the encrypted data and converts it back into readable information.

Why Encryption?

Prompt history contains:

- employee information
- generated phishing emails
- AI prompts
- campaign strategy
- sender identity

If someone gains direct access to the database,

they should not be able to read this information.

Encryption protects organizational data.

Previous Subject Retrieval

Function: `get_previous_subjects_for_employee()`

Purpose

Returns every subject line previously used for a specific employee.

Why?

The AI prompt includes instructions such as:

Do NOT generate any subject similar to:

Password Expiry Notice

Payroll Update

Attendance Correction

This forces Gemini to create something completely new.

Without this function,

employees would receive similar phishing emails repeatedly.

Previous CTA Retrieval

Function: `get_previous_ctas_for_employee()`

Purpose

Retrieves every previously used Call-To-Action.

Examples include:

Verify Account

Review Document

Login Securely

Update Password

View Invoice

The AI avoids generating the same action repeatedly, making campaigns more realistic.

Prompt Payload Collection

Function: `get_all_prompt_payloads_for_employee()`

Purpose

Returns the complete history of every phishing campaign generated for an employee.

Each stored record contains:

- AI prompt
- generated email
- scenario
- sender
- CTA
- campaign metadata

The Email Evolution Engine uses this historical information to evolve future phishing emails intelligently.

Previously Used Scenarios

Function: `get_used_scenario_ids_for_employee()`

Purpose

Determines which phishing scenarios have already been delivered to an employee.

Example

Suppose HR has three phishing scenarios.

Payroll Policy

Attendance Correction

Benefits Enrollment

If the employee has already received:

Payroll Policy

Attendance Correction

the AI automatically selects

Benefits Enrollment

instead.

This prevents scenario repetition and increases training effectiveness.

Campaign Attempt Counter

Function: `get_real_attempt_count_for_employee()`

Purpose

Calculates the actual number of phishing campaigns previously delivered to an employee.

This value is passed to the AI so it can gradually adjust the tone of future emails.

For example:

- First campaign: routine business communication.
- Second campaign: polite reminder.
- Third campaign: mild urgency.
- Fourth campaign: stronger urgency.
- Fifth and later campaigns: elevated urgency while still appearing legitimate.

This progressive approach prevents every phishing email from sounding identical.

Organization-wide Learning

Function: `get_winning_scenarios_org_wide()`

Purpose

This function analyzes all previous campaigns across the organization to identify which phishing scenarios have been the most successful.

Instead of learning only from one employee, the platform learns from organizational behavior.

For each historical campaign, it checks whether the campaign objective was achieved and counts successful scenarios. The most effective scenarios are then used as guidance for future AI-generated campaigns.

This creates a feedback loop where successful phishing themes influence future campaign strategy while still avoiding direct repetition.

9. Artificial Intelligence Email Evolution Engine

Overview

The Artificial Intelligence Email Evolution Engine is the core intelligence component of the platform. It transforms a basic phishing simulation into an adaptive and continuously evolving training system.

Unlike traditional phishing simulators that repeatedly send identical email templates, this engine analyzes previous campaign history, employee behavior, organizational success patterns, and department-specific attack scenarios before generating a completely new phishing email.

Its primary objective is to ensure that every phishing campaign appears realistic, relevant, and different from previous campaigns while maintaining a high level of authenticity.

The engine is implemented mainly within `email_evolution_engine.py` and works closely with the Campaign Quality Engine and Campaign Validator before any email is delivered to an employee.

AI Generation Workflow

The complete AI generation process follows the workflow below.

Administrator Starts Campaign



Retrieve Employee Information



Retrieve Previous Campaign History



Identify Department



Select Appropriate Threat Scenario



Choose Sender Identity



Build AI Prompt



Generate Email using Gemini AI



Validate Generated Campaign



Pass ?

No



Yes



Save Campaign History



Send Email



Generate Again

Design Philosophy

The AI engine follows a simple principle:

Every phishing email should appear as if it has never been sent before.

To achieve this objective, the engine does not simply ask Gemini to write an email.

Instead, it provides Gemini with extensive background information including:

- Employee department
- Employee designation
- Previous phishing history
- Previously used subject lines
- Previously used call-to-action phrases
- Previously used phishing scenarios

- Previous sender identities
- Organizational success statistics
- Campaign attempt number
- Required psychological strategy

This additional context enables the AI to generate emails that remain realistic while avoiding repetition.

Threat Scenario Library

Before generating an email, the engine first determines the appropriate phishing scenario.

The Threat Scenario Library organizes phishing scenarios according to department. Each scenario contains structured information such as:

- Scenario Identifier
- Scenario Title
- Business Context
- Payload Type

Examples include:

Human Resources

- Payroll Policy Update
- Attendance Correction
- Benefits Enrollment

Finance

- Vendor Invoice
- Expense Reimbursement
- Tax Clearance

Information Technology

- Password Expiration
- VPN Certificate Renewal
- Software License Renewal

Cyber Security

- Zero-Day Vulnerability
- Incident Report
- MFA Enrollment

Management

- Board Documents
- Executive Request
- Strategy Review

Using department-specific scenarios makes phishing emails closely resemble genuine organizational communication and improves simulation realism.

Scenario Selection

Function: `select_next_scenario()`

Purpose

Selects the most appropriate phishing scenario for the current campaign.

Selection Strategy

The function follows several rules.

Rule 1

If a scenario has never been used for this employee, it is preferred.

Rule 2

If multiple unused scenarios exist, the engine prefers one from a category that has not been used recently.

Rule 3

If organizational statistics indicate that certain phishing themes are particularly effective, those themes receive higher priority.

Rule 4

If every scenario has already been used, the engine selects the most suitable scenario while ensuring sufficient variation.

This intelligent selection prevents employees from repeatedly seeing the same phishing storyline.

Sender Identity Resolution

Function: `resolve_sender_identity()`

Real phishing attacks rarely originate from the same sender.

Therefore, the platform dynamically selects an internal sender identity based on the chosen phishing scenario.

For example:

Scenario	Sender Identity
Payroll	Payroll Team
Attendance	HR Operations
Vendor Invoice	Procurement Team
Password Reset	Identity & Access Management
Zero-Day Alert	Security Operations Center
Board Request	Executive Office

This variation makes phishing emails appear significantly more authentic and reduces the likelihood of employees recognizing repeated sender names.

Prompt Construction

Function: `build_prompt()`

This is the most important function in the AI engine.

Its responsibility is to construct the instruction that will be sent to Gemini AI.

Rather than asking the AI to "write a phishing email," the function supplies detailed organizational context so that the generated email aligns with previous campaign history and current objectives.

The generated prompt typically includes:

Employee Information

- Employee name
 - Department
 - Designation
-

Campaign Context

- Current campaign number
 - Previous employee behaviour
 - Previous campaign outcome
-

Memory

The prompt reminds the AI about:

- Previous subject lines
- Previous email themes
- Previous CTA phrases
- Previous scenarios

It explicitly instructs the AI not to reuse or closely imitate any of these elements.

Organizational Intelligence

The prompt also incorporates organization-wide learning.

If previous campaigns demonstrate that certain phishing themes are particularly successful, the AI is instructed to create a different scenario within the same general theme rather than copying earlier emails.

Tone Control

The prompt adjusts the email tone according to the number of previous attempts.

Attempt	Tone
First	Routine corporate communication
Second	Gentle reminder
Third	Mild urgency
Fourth	Important pending request
Fifth and later	Elevated urgency while remaining professional

This gradual escalation makes repeated campaigns appear natural rather than repetitive.

Gemini Email Generation

After the prompt is completed, it is submitted to Google Gemini.

Gemini returns:

- Email subject
- Email body

The response is then passed through the application's formatting functions to remove unwanted markdown, normalize spacing, convert paragraphs into HTML, and ensure a consistent format before validation.

Campaign Validation

Every AI-generated email must pass quality validation before it can be delivered.

The Campaign Validator evaluates:

- Subject uniqueness

- Body uniqueness
- Call-to-action uniqueness
- Sender diversity
- Scenario reuse

If any validation fails, the Campaign Quality Engine generates feedback explaining why the campaign was rejected. That feedback is converted into instructions for the AI, which generates a revised email.

This process continues until a campaign satisfies all validation requirements or the retry limit is reached.

Campaign Memory

The AI engine maintains long-term campaign memory by using encrypted historical records stored in the database.

Instead of generating emails in isolation, every new campaign is influenced by previous campaigns delivered to the same employee.

The historical information includes:

- Previous prompts
- Previous AI-generated emails
- Previous scenarios
- Previous senders
- Previous CTA phrases
- Previous campaign results

This memory allows the platform to evolve phishing campaigns over time while maintaining originality.

Outcome

By combining structured threat scenarios, organizational memory, adaptive prompt construction, sender variation, and automated validation, the AI Email Evolution Engine generates phishing campaigns that remain realistic, diverse, and resistant to repetition. This capability distinguishes the platform from traditional phishing simulation tools that rely on static templates.

10. Campaign Quality Engine & Campaign Validation

Overview

Generating a phishing email using Artificial Intelligence is only the first step in the campaign creation process.

Although the AI produces realistic emails, there is still a possibility that it may unintentionally generate content that resembles previous phishing campaigns. Reusing similar subjects, sender identities, or email content would reduce the effectiveness of security awareness training because employees could begin recognizing recurring patterns.

To prevent this problem, the platform introduces a dedicated **Campaign Quality Engine** that performs automated quality assurance before any phishing email is delivered.

Instead of trusting the AI blindly, the platform verifies that every generated campaign satisfies organizational quality standards.

Only emails that successfully pass all validation checks are approved for delivery.

Why is a Validation Engine Required?

Consider the following example.

Campaign 1

Subject:

Microsoft Password Expiring Today

Campaign 2

Subject:

Your Microsoft Password Will Expire Today

Although the wording is slightly different, both subjects communicate exactly the same message.

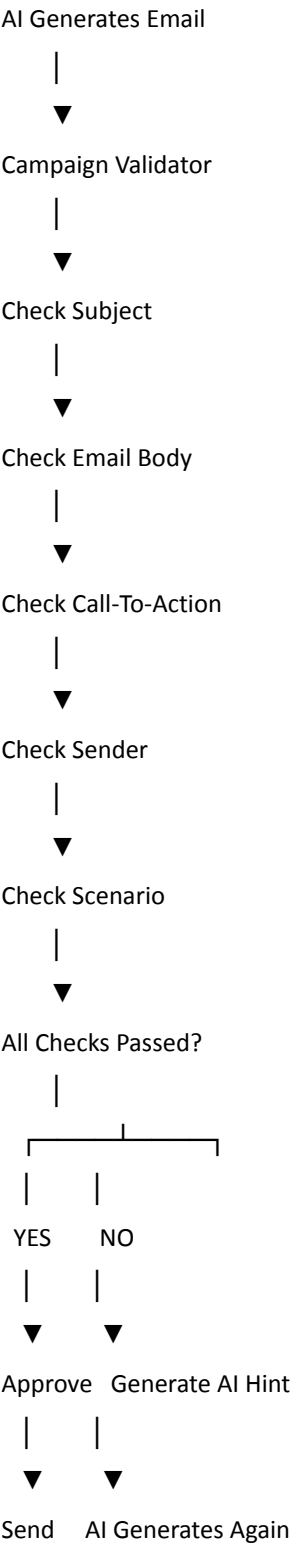
From an employee's perspective, both emails appear almost identical.

If similar campaigns continue to be delivered, employees eventually learn to recognize them, reducing the realism of phishing simulations.

The Campaign Validation Engine identifies this similarity and forces the AI to generate a completely different phishing email instead.

Validation Workflow

Every AI-generated email passes through the following workflow.



Purpose

The Campaign Quality Engine acts as the quality control department of the platform.

Rather than performing similarity calculations itself, it coordinates the validation process and prepares feedback for the AI whenever a campaign fails validation.

Its responsibilities include:

- Receiving AI-generated phishing emails.
- Invoking the Campaign Validator.
- Collecting validation results.
- Determining whether the campaign passes.
- Preparing regeneration instructions.
- Returning the final quality report.

This module serves as the communication bridge between the AI Email Generation Engine and the Campaign Validator.

Validation Rules

The platform evaluates every campaign using five independent quality checks.

A campaign must satisfy **all** checks before it can be delivered.

Rule 1 – Subject Validation

Purpose

Checks whether the generated email subject is too similar to subjects previously sent to the same employee.

Why?

Employees often remember subject lines.

If identical or nearly identical subjects appear repeatedly, future phishing emails become easier to identify.

Example

Previously Sent

Password Expiry Notification

Generated

Password Expiration Notification

Although the wording differs slightly, the meaning is nearly identical.

The validator detects this similarity and rejects the campaign.

The validator calculates similarity using a combination of text sequence matching and keyword overlap.

If similarity exceeds the configured threshold, the subject is rejected.

Rule 2 – Email Body Validation

Purpose

Checks whether the generated email body closely resembles previous phishing emails.

Why?

Changing only the subject is not sufficient.

If the message body remains the same,

employees can still recognize the phishing simulation.

Example

Old Email

Please review the revised payroll policy...

New Email

Kindly review the updated payroll policy...

Even though several words have changed,

the overall message remains almost identical.

The validator rejects this email and requests a new storyline.

Rule 3 – Call-To-Action Validation

Purpose

Ensures that hyperlinks encourage different user actions across campaigns.

Example

Previously Used

Verify Account

Generated

Verify Your Account

These CTAs are almost identical.

Instead, the validator encourages alternatives such as

Review Updated Policy

Download Secure Document

Open Employee Portal

Access Payroll Dashboard

Changing the action phrase increases realism.

Rule 4 – Sender Validation

Purpose

Checks whether the same internal department or sender identity has been used recently.

Why?

Real organizations send emails from many different departments.

Receiving repeated emails from

IT Support

every week appears suspicious.

Instead, the platform rotates sender identities.

Possible examples include:

- Payroll Team
- HR Operations
- Procurement Team
- Security Operations Center
- Executive Office
- Finance Department

The validator rejects campaigns that repeatedly use the same sender within recent history.

Rule 5 – Scenario Validation

Purpose

Ensures that phishing scenarios are not reused unnecessarily.

Example

Previous Campaign

Payroll Policy

Current Campaign

Payroll Policy

Rejected.

Instead,

the AI may choose

Benefits Enrollment

Attendance Review

Tax Declaration

Expense Reimbursement

Changing the business scenario significantly improves realism.

Similarity Detection

The validator does not rely on exact word matching.

Instead, it combines two different techniques.

Sequence Similarity

This technique compares the order of characters within two pieces of text.

It is useful for detecting small wording changes.

Example

Password Expiry

Password Expiration

Even though the words differ,

the overall structure remains highly similar.

Jaccard Similarity

This technique compares important keywords instead of the exact sentence.

For example

Old

Review payroll policy immediately

New

Please review updated payroll policy

Most important words are shared,

so the similarity remains high.

Combined Similarity

The platform combines both methods to obtain a more reliable similarity score.

This reduces false positives while improving duplicate detection.

Similarity Thresholds

The validator defines acceptable similarity limits.

Component	Maximum Similarity
Subject	72%
Email Body	68%
Call-To-Action	80%

If similarity exceeds these values,

the campaign is rejected and regenerated.

These thresholds were selected to balance originality with realistic corporate language.

AI Regeneration

When validation fails,

the platform does not simply request another random email.

Instead,

the Campaign Quality Engine generates a clear explanation for the AI.

Example

Generate a completely different subject.

Rewrite the email using a different business story.

Use another internal department.

Select another phishing scenario.

Change the Call-To-Action.

These instructions guide Gemini toward producing a genuinely different phishing campaign instead of making only superficial wording changes.

Validation Report

Every validation produces a structured quality report.

The report contains:

- Validation status
- Failed validation rules
- Novelty score
- Regeneration guidance

- Pass or Fail result

This report is useful for debugging, testing, and monitoring AI performance during development.

If validation succeeds, the email proceeds to storage and delivery. If validation fails, the report becomes the basis for the next AI generation attempt.

Benefits of the Validation Engine

The Campaign Quality Engine provides several operational benefits:

- Prevents repetitive phishing emails.
 - Maintains long-term campaign diversity.
 - Increases realism by rotating business scenarios and sender identities.
 - Reduces employee familiarity with simulation patterns.
 - Improves the accuracy of phishing awareness measurements.
 - Provides structured feedback for AI regeneration.
 - Ensures every approved campaign meets organizational quality standards.
-

Chapter Summary

The Campaign Quality Engine acts as the platform's quality assurance layer. It ensures that every phishing email generated by the AI is unique, realistic, and sufficiently different from previous campaigns. By combining similarity analysis, sender rotation, scenario validation, and AI regeneration, the platform maintains high-quality phishing simulations that remain effective over time.

11. Risk Assessment Engine

Overview

The Risk Assessment Engine is responsible for measuring the cybersecurity awareness level of every employee based on their behaviour during phishing simulation campaigns.

Instead of simply recording whether an employee clicked a phishing link, the engine analyzes every recorded interaction, converts these activities into numerical values, applies organizational weighting factors, normalizes the results, classifies the overall risk level, and updates enterprise dashboards.

This approach provides administrators with measurable cybersecurity metrics rather than simple pass-or-fail results.

The Risk Assessment Engine consists of four major modules:

- risk_engine.py
- risk_calculator.py
- risk_classifier.py
- department_risk.py

Each module performs a specific task within the overall risk calculation process.

Why is a Risk Engine Required?

Traditional phishing awareness platforms usually provide only two outcomes:

- Employee clicked.
- Employee did not click.

While useful, this information is insufficient for organizational decision-making.

For example, consider the following employees.

Employee	Behaviour
Employee A	Opened email only
Employee B	Clicked phishing link
Employee C	Submitted credentials

Although all three interacted with the phishing campaign, the security implications are very different.

The Risk Assessment Engine converts these differences into measurable numerical scores.

Risk Calculation Workflow

The complete risk assessment process follows the workflow below.

Employee Performs Action



Simulation Event Logged



Event Counts Calculated



Base Risk Score Computed



Repeat Behaviour Penalty Applied



Role Weight Applied



Department Weight Applied



Training Rewards Applied



Score Normalized



Risk Classification



Employee Ranking



Department Risk Calculation



Dashboard Updated

Event Types

Every employee interaction is converted into one or more event types.

Each event represents a different level of phishing success.

The platform currently recognises the following events.

Event	Description
IMAGE	Employee opened the email and downloaded the tracking image.
LINK	Employee clicked the phishing hyperlink.
CREDENTIAL	Employee submitted credentials into the phishing portal.
MALWARE	Reserved for malware simulation campaigns.
MFA	Reserved for multi-factor authentication simulations.

Each event contributes differently towards the final risk score.

Event Weighting

Every event carries a predefined numerical weight.

More dangerous actions contribute more heavily to the employee's overall cybersecurity risk.

Event	Weight
IMAGE	2
LINK	10
MFA	20
CREDENTIAL	50
MALWARE	60

This weighting system reflects the relative severity of employee actions during phishing simulations.

For example, merely opening an email is significantly less risky than submitting credentials.

Formula 1 – Base Event Score

The first stage of risk calculation determines the employee's base score.

The formula is:

Base Risk Score = $\sum(\text{Event Count} \times \text{Event Weight})$

Example

Suppose an employee performs the following actions.

Event	Count
IMAGE	2
LINK	1
CREDENTIAL	1

Calculation

$(2 \times 2) + (1 \times 10) + (1 \times 50) = 64$

This value becomes the employee's base cybersecurity risk score before additional adjustments are applied.

Formula 2 – Repeat Behaviour Penalty

Employees who repeatedly fall victim to phishing simulations present a greater organizational risk.

The platform therefore applies an additional penalty when repeated high-risk behaviour is detected.

The mathematical model is

$\text{Penalty} = \text{Base Score} \times ((\text{Weight}^{\text{Count}} - 1) / (\text{Weight} - 1))$

This formula increases risk more aggressively for repeated credential submissions than for occasional mistakes.

As a result, employees who repeatedly submit credentials receive significantly higher risk scores than those who make isolated errors.

Formula 3 – Role Weighting

Different organizational roles carry different levels of business impact.

For example,

an administrator account is generally more valuable to attackers than a standard employee account.

The platform therefore applies role-based weighting.

Example values include:

Role	Weight
Employee	1.0
Manager	1.2
Administrator	1.3

This adjustment reflects the increased organizational impact of compromising privileged users.

Formula 4 – Department Weighting

Departments have different exposure levels to phishing attacks.

For example,

Finance employees frequently process payments,

while Human Resources personnel regularly manage payroll and employee records.

The platform therefore adjusts risk according to departmental criticality.

Department	Weight
Finance	1.5
Management	1.4
HR	1.2
Default	1.0
IT	0.9

Departments handling sensitive financial or executive information receive higher weighting factors.

Formula 5 – Positive Behaviour Rewards

The platform can also reduce employee risk scores.

Examples include:

- Completion of cybersecurity awareness training.
- Reporting suspicious phishing emails.
- Demonstrating secure behaviour during campaigns.

Instead of only penalising mistakes, the engine also rewards positive security behaviour.

This encourages continuous improvement rather than punishment alone.

Formula 6 – Risk Normalization

Raw scores can become very large after weighting and penalties.

To ensure consistency across the organisation, the platform converts all scores into a standard scale from **0 to 100**.

The normalization formula is

$$\text{Normalized Risk} = (\text{Raw Score} / (\text{Raw Score} + 100)) \times 100$$

After normalization, every employee receives a comparable cybersecurity risk score regardless of the number of campaigns completed.

Risk Classification

After normalization,

the numerical score is converted into an easy-to-understand risk category.

The platform currently uses four levels.

Score	Risk Level
0–19	LOW
20–39	MEDIUM

40–69	HIGH
70–100	CRITICAL

These categories simplify dashboard reporting and enable administrators to prioritise remediation activities.

Employee Ranking

Once every employee's score has been calculated,

the platform ranks employees from highest risk to lowest risk.

The employee with the highest calculated score receives Rank 1.

This ranking helps administrators quickly identify individuals requiring immediate awareness training or additional monitoring.

Risk Percentile

Ranking alone may not provide sufficient context in large organisations.

The platform therefore calculates an employee's percentile.

The percentile indicates how an employee compares with the rest of the organisation.

For example,

an employee in the 95th percentile is riskier than approximately 95% of other employees.

This metric supports executive reporting and trend analysis.

Department Risk Calculation

Individual employee scores are also aggregated into department-level metrics.

The platform uses the following formula:

Department Risk=(0.70 × Department Average Risk)+(0.30 × Department Maximum Risk)

This approach balances overall departmental performance with the impact of high-risk individuals.

For example,

a department containing one extremely vulnerable employee should not appear completely safe simply because all other employees performed well.

Risk Breakdown

For transparency, the platform can generate a detailed explanation of how an employee's final score was calculated.

The breakdown includes:

- Recorded phishing events.
- Base event score.
- Department weighting.
- Applied penalties.
- Applied rewards.
- Final normalized score.
- Assigned risk level.

This information allows administrators to understand exactly why an employee received a particular risk rating and supports evidence-based decision-making.

Dashboard Integration

The calculated risk information is synchronized with the employee database.

The dashboard then displays:

- Individual risk scores.
- Risk levels.
- Department risk scores.
- Employee rankings.
- Risk percentiles.
- Organizational cybersecurity posture.

Whenever new phishing events are recorded, the Risk Engine recalculates these values so that dashboard information remains current.

Benefits of the Risk Assessment Engine

The Risk Assessment Engine provides several operational advantages:

- Converts phishing behaviour into measurable cybersecurity metrics.
 - Prioritises employees requiring additional awareness training.
 - Enables department-level cybersecurity comparisons.
 - Supports executive reporting through rankings and percentiles.
 - Rewards positive security behaviour in addition to penalising risky actions.
 - Provides transparent explanations for every calculated risk score.
 - Maintains a consistent 0–100 scoring scale across the organisation.
-

Chapter Summary

The Risk Assessment Engine transforms employee interactions into meaningful cybersecurity intelligence. By combining event weighting, behavioural analysis, organizational context, normalization, ranking, and departmental aggregation, the platform enables administrators to monitor individual and organizational cyber risk in a structured and measurable manner. This quantitative approach provides a stronger basis for security awareness planning than simple click-rate reporting alone.

12. Event Tracking and Monitoring System

Overview

The Event Tracking and Monitoring System records every interaction performed by an employee during a phishing simulation campaign.

The objective of this module is not only to determine whether an employee clicked a phishing email, but to capture the complete sequence of user actions from email delivery until the end of the simulation.

Each recorded event becomes part of the employee's cybersecurity history and serves as the primary source of information for the Risk Assessment Engine, administrative dashboards, campaign reports, and organizational analytics.

The Event Tracking System also maintains an encrypted audit trail, ensuring that sensitive simulation data remains protected even if unauthorized database access occurs.

Why Event Tracking is Required

Without event tracking,

the platform could only answer one question:

"Was the email delivered?"

However, cybersecurity awareness depends on understanding user behaviour after email delivery.

The platform therefore records multiple stages of employee interaction.

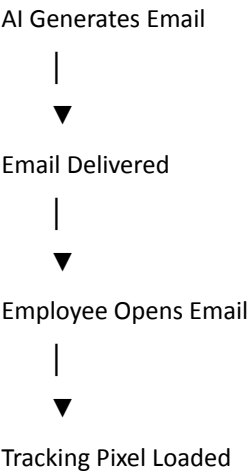
Examples include:

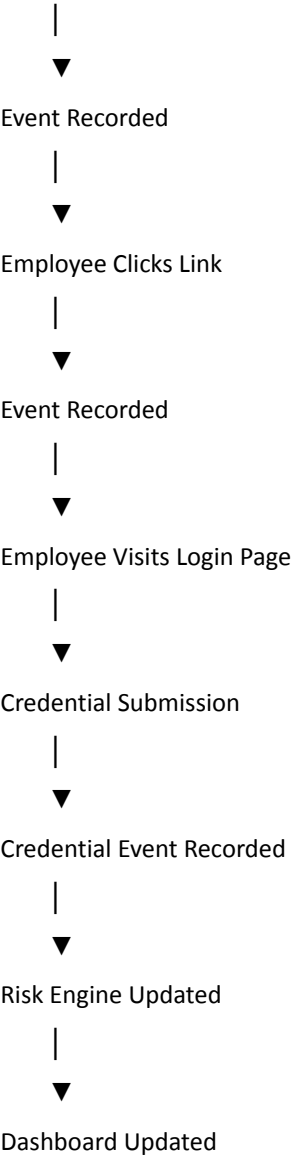
- Did the employee open the email?
- Did the employee load tracking images?
- Did the employee click the phishing link?
- Did the employee submit credentials?
- Which campaign generated the interaction?
- Which phishing scenario caused the interaction?
- When did the interaction occur?

This information provides administrators with a complete behavioural timeline instead of a simple success or failure indicator.

Event Tracking Workflow

The complete monitoring process follows the workflow below.





Event Types

The platform currently records multiple categories of employee activity.

Event Type	Description
IMAGE	Employee opened the email and the embedded tracking image was downloaded.
LINK	Employee clicked the phishing hyperlink contained within the email.
CREDENTIAL	Employee entered login credentials into the simulated phishing portal.

Each event is stored separately and contributes independently towards employee risk calculations.

Secure Event Logging

Function: `secure_log_event()`

Purpose

This function records every phishing interaction securely inside the database.

Rather than storing plain text information,

the platform encrypts every event before storage.

Information Stored

Every event contains:

- Employee ID
- Employee Name
- Employee Email
- Department
- Campaign ID
- Prompt Version
- Event Type
- Payload Type
- Event Time
- Calculated Risk Value

Before writing this information into the database,

the complete event record is encrypted using the platform encryption key.

Only authorised application components can decrypt this information.

This approach protects employee privacy and maintains the confidentiality of phishing simulation records.

Payload Types

Every phishing campaign contains a payload.

The payload determines what the employee is expected to do.

Examples include:

Payload	Purpose
IMAGE	Measure whether the email was opened.
LINK	Measure whether the employee clicked the phishing link.
CREDENTIAL	Measure whether credentials were submitted.

Different payloads contribute different risk values because not every employee action has the same security impact.

Risk Contribution

Each recorded payload contributes towards the employee's overall cybersecurity risk.

Example values include:

Payload	Example Risk Value
IMAGE	5
LINK	30
CREDENTIAL	60

Submitting credentials is therefore considered significantly more serious than simply opening an email.

Retrieving Event History

Function: `get_all_logged_events()`

Purpose

Retrieves every recorded phishing interaction stored inside the database.

Internal Working

When called,

the function performs the following steps:

1. Connects to PostgreSQL.
2. Reads encrypted simulation records.
3. Decrypts every stored event.
4. Converts encrypted JSON back into readable information.
5. Returns the complete event history.

This function is primarily used by dashboards, reporting modules, and the Risk Assessment Engine.

Employee Event History

Function: `get_user_event_history()`

Purpose

Returns every phishing interaction associated with a single employee.

Rather than searching the database repeatedly,

this function filters the event history using the employee's email address.

Example

Suppose an employee participated in five phishing campaigns.

The returned history may contain:

Campaign	Interaction
Campaign 1	Email Opened
Campaign 2	Link Clicked
Campaign 3	Credential Submitted
Campaign 4	Email Ignored
Campaign 5	Link Clicked

This history is later analysed by the Risk Assessment Engine to calculate long-term cybersecurity awareness.

Target Achievement Detection

Function: `is_target_achieved()`

Purpose

Determines whether the employee successfully completed the objective of a phishing simulation.

The expected objective depends upon the campaign.

Examples include:

Target Goal	Required Behaviour
CLICK	Employee clicked the phishing link.
CREDENTIAL	Employee submitted credentials.

If the required behaviour has already been recorded,

the campaign is marked as successful.

This information updates campaign statistics and administrator reports.

Previous Campaign Result

Function: `get_previous_result_for_user()`

Purpose

Determines how an employee responded during previous phishing simulations.

Possible outcomes include:

Result	Meaning
NO_PREVIOUS_TRIGGER	Employee has never received a phishing simulation.

TRIGGERED_NO_SUCCESS	Employee received the email but did not complete the target objective.
CLICK_CAPTURED	Employee clicked the phishing link.
CREDENTIAL_CAPTURED	Employee submitted credentials.

This historical result becomes one of the inputs used by the AI Email Evolution Engine when constructing future phishing campaigns.

Identifying Caught Employees

Function: `get_caught_users()`

Purpose

Builds a list of employees who have interacted successfully with phishing simulations.

The returned information includes:

- Employee email
- Timestamp of successful interaction

This information is used to display campaign status on the administrator dashboard.

Employees who have completed the phishing objective can immediately be identified without recalculating historical event data.

Dashboard Integration

The Event Tracking System continuously supplies live data to multiple dashboard components.

Examples include:

- Campaign completion status
- Employee phishing history
- Risk calculations
- Employee status indicators
- Organizational statistics

- Security reports

Whenever a new phishing interaction occurs,

the dashboard reflects updated information after the event has been processed.

Security Features

Several security measures protect the Event Tracking System.

Encryption

Every event record is encrypted before being written to the database.

Audit Trail

All employee interactions are permanently associated with campaign identifiers and timestamps.

Integrity

Campaign IDs and Prompt Version IDs ensure that every interaction can be traced back to the exact phishing email that generated it.

Confidentiality

Sensitive employee behaviour cannot be interpreted directly from the database because event records remain encrypted.

Benefits of the Event Tracking System

The Event Tracking System provides several important capabilities:

- Records the complete phishing interaction lifecycle.
- Maintains encrypted audit records.

- Supports accurate employee risk calculations.
 - Tracks campaign objectives automatically.
 - Enables detailed behavioural analytics.
 - Supplies live information to dashboards and reports.
 - Preserves complete campaign history for future AI learning.
-

Chapter Summary

The Event Tracking and Monitoring System acts as the behavioural memory of the platform. Every phishing interaction—from email opening to credential submission—is securely recorded, encrypted, and linked to the originating campaign. These records support risk assessment, campaign analytics, dashboard reporting, and future AI campaign evolution, making the tracking system a central component of the overall cybersecurity awareness platform.

13. Email Delivery System

Overview

The Email Delivery System is responsible for securely delivering AI-generated phishing simulation emails to employees.

Once the Artificial Intelligence Engine has generated a phishing email and the Campaign Validation Engine has approved it, the Email Delivery System prepares the email for delivery by adding corporate branding, department-specific sender identities, employee-specific tracking links, tracking images, legal disclaimers, and personalized signatures.

The objective of this module is to produce phishing emails that closely resemble legitimate corporate communications while simultaneously enabling the platform to monitor employee interactions.

The Email Delivery System is primarily implemented within `app.py` and works together with the AI Email Evolution Engine, Event Tracking System, and Campaign Management Layer.

Why an Email Delivery System is Required

Generating a phishing email alone is not sufficient.

The platform must also ensure that the email:

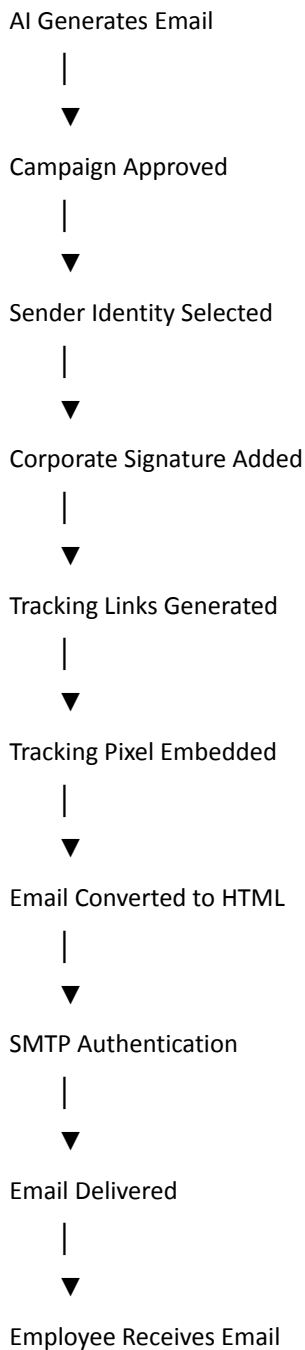
- Appears authentic.

- Uses realistic sender information.
- Contains organizational branding.
- Includes employee-specific tracking.
- Records user behaviour.
- Supports different phishing objectives.

The Email Delivery System performs all these tasks automatically before the email is transmitted.

Email Delivery Workflow

The complete email delivery process is illustrated below.



Email Components

Every phishing email consists of several individual components.

Component	Purpose
Subject	Attracts employee attention.
Email Body	Contains the phishing scenario generated by AI.
Sender Identity	Makes the email appear to originate from an internal department.
Call-To-Action	Encourages the employee to perform the expected action.
Tracking Link	Records employee link clicks.
Tracking Pixel	Detects email opening.
Corporate Signature	Improves authenticity.
Legal Disclaimer	Replicates legitimate corporate emails.

Together, these components create a realistic phishing simulation.

Sender Identity Selection

Before an email is delivered, the platform selects an appropriate sender identity based on the phishing scenario.

Examples include:

Department	Sender Name
Human Resources	Payroll Management Office
Finance	Accounts Payable Desk
Information Technology	Hawkins Security Desk
Cyber Security	Threat Intelligence Unit
Management	Executive Board Office

The sender name displayed to the employee changes automatically according to the selected scenario.

This variation significantly improves realism because genuine organizations rarely send every email from the same individual.

Corporate Signature Generation

Function: `get_email_signature()`

Purpose

Every department uses a unique email signature.

The signature contains:

- Employee name
- Job designation
- Department
- Organization
- Office location

This information is appended automatically to every AI-generated phishing email.

Using department-specific signatures makes phishing simulations closely resemble genuine internal communications.

Corporate Legal Disclaimer

The platform appends the standard Hawkins corporate legal disclaimer to all phishing simulation emails.

The disclaimer closely resembles that used in legitimate organizational email communications.

Including the disclaimer provides several benefits:

- Improves authenticity.
- Reduces employee suspicion.
- Replicates genuine corporate communication standards.

The disclaimer is automatically inserted before email delivery.

Dynamic Call-To-Action Generation

The Call-To-Action (CTA) presented to employees varies according to the phishing scenario.

Examples include:

Scenario	CTA
Payroll Update	Review Revised Policy
Vendor Invoice	Process Invoice
Password Reset	Verify Account
Security Alert	Emergency Login
Executive Request	Access Confidential Documents

Changing the CTA across campaigns prevents employees from recognizing repetitive phishing patterns and increases simulation realism.

Tracking Link Generation

Every phishing email contains a unique tracking hyperlink.

The destination depends on the phishing objective.

Link-Based Campaigns

Employees are redirected to a tracking endpoint that records the click before displaying the next page.

Credential-Based Campaigns

Employees are redirected to a simulated login portal.

This allows the platform to determine whether credentials were submitted during the phishing simulation.

Every generated tracking link contains:

- Employee identifier
- Campaign identifier

- Prompt version identifier

These identifiers allow every interaction to be associated with the exact phishing email that generated it.

Tracking Pixel

The platform embeds a small invisible tracking image inside every HTML email.

When the employee opens the email,

their email client attempts to download this image.

The download request automatically informs the platform that the email has been opened.

This enables administrators to distinguish between:

- Email delivered but never opened.
- Email opened.
- Email clicked.
- Credential submission.

Tracking pixels therefore provide the earliest indication of employee interaction.

HTML Email Assembly

Before delivery,

the Email Delivery System converts the generated content into a complete HTML email.

The HTML email includes:

- AI-generated email body.
- Personalized greeting.
- Call-To-Action button or hyperlink.
- Department signature.
- Corporate branding.
- Promotional banner (if configured).
- Tracking pixel.
- Legal disclaimer.

This assembly process ensures that all phishing emails follow a consistent corporate appearance.

SMTP Delivery

Function: `send_simulation_email()`

Purpose

This function performs the actual email transmission.

Internal Process

The function performs the following sequence:

1. Selects the appropriate sender identity.
2. Generates tracking links.
3. Creates the HTML email.
4. Connects to the SMTP server.
5. Authenticates using configured credentials.
6. Sends the email.
7. Closes the SMTP session.

If an error occurs during delivery, the exception is captured and logged so that administrators can investigate the failure.

This centralized approach ensures that every phishing email is delivered using the same standardized procedure.

Email Personalization

Every employee receives a personalized phishing email.

The personalization includes:

- Employee name.
- Department.
- Relevant phishing scenario.
- Personalized greeting.
- Department-specific sender.
- Customized Call-To-Action.

- Unique tracking identifiers.

Because every email is generated specifically for an individual employee, large-scale campaigns avoid appearing identical across the organization.

Security Considerations

The Email Delivery System incorporates several controls to support secure operation.

Personalized Tracking

Each email contains unique campaign and employee identifiers to ensure accurate event attribution.

Controlled Delivery

Emails are delivered only after successful AI validation and campaign approval.

Auditability

Every delivered email is linked to campaign history, prompt version, and employee records, enabling complete traceability throughout the phishing simulation lifecycle.

Benefits of the Email Delivery System

The Email Delivery System provides several operational advantages:

- Delivers realistic AI-generated phishing emails.
- Supports personalized communication for every employee.
- Uses department-specific sender identities and signatures.
- Embeds tracking links and tracking pixels automatically.
- Supports both link-click and credential-harvesting simulations.
- Maintains consistent corporate branding.
- Integrates directly with event tracking and campaign history.

Chapter Summary

The Email Delivery System transforms validated AI-generated content into realistic corporate phishing simulations. By combining personalized messaging, dynamic sender identities, embedded tracking mechanisms, HTML formatting, and secure SMTP delivery, the platform creates authentic phishing campaigns while ensuring that every employee interaction can be accurately monitored and analysed.

14. Security Architecture

Overview

Cybersecurity is not only the objective of this platform but also a fundamental design principle.

Because the platform stores sensitive employee information, AI-generated phishing campaigns, administrator credentials, campaign history, and phishing interaction records, multiple security mechanisms have been implemented throughout the application.

Rather than relying on a single protection mechanism, the platform applies multiple independent security controls. Each control protects a different layer of the application, ensuring that the compromise of one component does not expose the entire system.

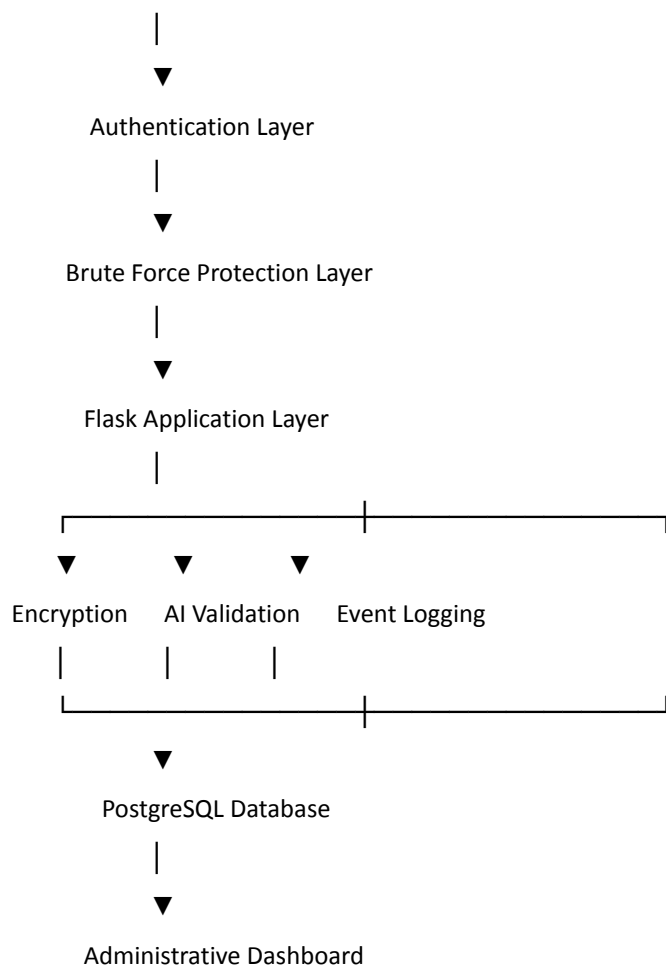
The implemented security architecture focuses on five primary objectives:

- Confidentiality
- Integrity
- Availability
- Authentication
- Accountability

Together, these controls protect both the application and the sensitive data it processes.

Security Architecture Overview

The platform applies security controls at multiple layers.



Every layer performs a specific security function.

Data Encryption

Purpose

One of the most important security mechanisms implemented within the platform is encryption.

Instead of storing sensitive information in plain text, confidential campaign data is encrypted before being written into the database.

The application automatically generates an encryption key if one does not already exist. This key is then loaded whenever the application starts and is used throughout the platform for encryption and decryption operations.

Information Protected by Encryption

The following information is encrypted before storage:

- AI prompts
- AI-generated phishing emails
- Campaign history
- Employee campaign information
- Simulation event records
- Employee interaction history

If an unauthorized individual gains direct access to the database, these records cannot be interpreted without the encryption key.

Prompt Encryption

Purpose

Every phishing campaign generated by Artificial Intelligence represents valuable organizational information.

The platform therefore encrypts every AI prompt before storing it.

The encrypted record includes:

- Employee information
- Generated subject
- Generated email body
- Selected phishing scenario
- Sender identity
- Call-To-Action
- Campaign information

Whenever historical campaign information is required, the application decrypts the stored record internally before using it.

This allows the Email Evolution Engine to learn from previous campaigns while ensuring that historical prompts remain protected inside the database.

Secure Event Storage

Employee behaviour is considered sensitive information.

Every interaction recorded during phishing simulations is therefore encrypted before storage.

Examples include:

- Email opened
- Link clicked
- Credentials submitted

The encrypted event record is stored together with campaign identifiers and timestamps.

Only the application can decrypt these records when calculating employee risk or displaying dashboard information.

Administrator Authentication

Access to the administrative dashboard is restricted.

Only authenticated administrators can:

- Create phishing campaigns.
- View employee information.
- Access risk reports.
- Monitor phishing simulations.
- View organizational statistics.

This prevents unauthorized users from managing phishing campaigns or accessing sensitive organizational information.

Brute Force Protection

Purpose

Administrator accounts represent one of the most valuable assets within the platform.

To prevent password guessing attacks, the platform continuously monitors failed login attempts.

The protection system performs the following functions:

- Counts consecutive failed login attempts.
- Stores failed attempts inside the database.
- Automatically locks the account after the configured limit is reached.

- Removes the lock automatically after the lock duration expires.
- Resets the failed attempt counter following a successful login.

The default configuration allows a maximum of **five** failed login attempts before the account is temporarily locked for **fifteen minutes**.

Login Attempt Database

The Brute Force Protection module maintains a dedicated database table that stores:

- Username
- Failed login attempts
- Lock expiration time

Whenever an administrator attempts to log in, the application checks this table before authenticating the user.

If the account is currently locked, access is denied until the lock period expires.

Automatic Lock Release

Account locks are temporary.

When the configured lock duration expires, the platform automatically removes the lock and resets the failed login counter.

This ensures that legitimate administrators regain access without requiring manual database intervention.

Security Alert Notifications

The platform immediately informs administrators whenever important security events occur.

Two major alerts are currently implemented.

Administrator Login Alert

Whenever an administrator successfully signs into the application, an automated notification email is generated.

The notification contains:

- Username
- Login time
- Source IP address
- Login status

This enables administrators to detect unauthorized access quickly if a login occurs unexpectedly.

Brute Force Attack Alert

If repeated authentication failures exceed the permitted threshold, the platform immediately generates a high-priority security alert.

The alert contains:

- Username
- Failed attempt count
- Source IP address
- Detection time
- Account lock duration

This notification allows administrators to investigate potential password guessing attacks while the affected account remains temporarily locked.

Campaign Integrity

Every phishing campaign is assigned a unique campaign identifier.

Similarly, every generated AI prompt receives its own prompt version identifier.

These identifiers are attached to:

- Campaign records
- Event logs
- Employee interactions

- Risk calculations

This structure ensures that every recorded event can always be traced back to the exact phishing email responsible for generating it.

Such traceability is essential for reporting, auditing, and incident investigation.

Audit Trail

The platform maintains a permanent audit trail throughout the phishing simulation lifecycle.

Important events recorded include:

- Campaign creation
- Employee assignment
- AI prompt generation
- Email delivery
- Email opening
- Link clicking
- Credential submission
- Risk calculation
- Campaign completion

This audit trail enables administrators to reconstruct the complete history of any phishing simulation.

Database Protection

The PostgreSQL database acts as the central repository for application information.

Rather than allowing unrestricted access, all database operations occur through controlled application functions.

The application performs:

- Secure database connections.
- Controlled SQL operations.
- Encrypted data storage.
- Consistent transaction management.

This design minimizes direct database exposure and centralizes data access within the application.

AI Safety Controls

Although Artificial Intelligence generates phishing emails, the platform does not immediately trust the generated output.

Every AI-generated campaign passes through multiple validation stages before delivery.

These controls verify:

- Subject originality.
- Email body originality.
- Sender diversity.
- Call-To-Action uniqueness.
- Scenario uniqueness.

Only campaigns that satisfy all validation requirements are approved.

This validation layer protects against repetitive or low-quality phishing simulations and improves overall campaign reliability.

Security Benefits

The implemented security architecture provides several important advantages:

- Encrypts sensitive campaign information before storage.
 - Protects administrator accounts against brute-force attacks.
 - Automatically detects repeated authentication failures.
 - Generates real-time administrator security notifications.
 - Preserves a complete audit trail.
 - Prevents unauthorized access to campaign history.
 - Ensures AI-generated content satisfies organizational quality standards.
 - Maintains confidentiality of employee phishing behaviour.
-

Chapter Summary

Security has been integrated into every major component of the platform rather than treated as an additional feature.

Encryption protects sensitive data at rest, authentication controls restrict access to administrative functions, brute-force

protection safeguards privileged accounts, automated alerts notify administrators of important security events, and validation mechanisms ensure the integrity of AI-generated campaigns. Together, these controls provide a layered security architecture that supports the platform's operational and organizational objectives.

15. Administrator Dashboard

Overview

The Administrator Dashboard is the central management interface of the AI-Powered Phishing Awareness & Training Platform.

It provides administrators with a consolidated view of the organization's cybersecurity awareness posture. Instead of requiring administrators to inspect multiple databases or log files, the dashboard presents campaign information, employee risk, departmental statistics, security alerts, and campaign analytics through a single interface.

The dashboard is designed to support daily operational monitoring, campaign management, executive reporting, and cybersecurity decision-making.

Its primary objective is to transform raw technical data into information that administrators can easily understand and act upon.

Purpose of the Dashboard

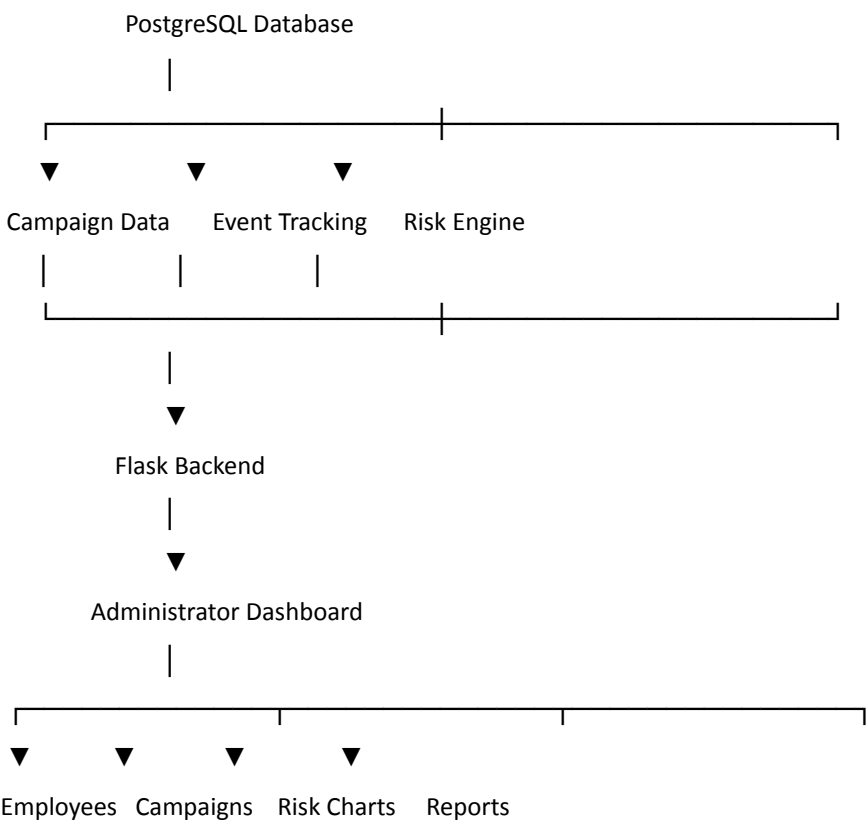
The dashboard enables administrators to perform the following activities:

- Monitor phishing campaigns.
- View employee cybersecurity awareness.
- Track employee interactions.
- Monitor organizational cyber risk.
- Review department-wise performance.
- Identify high-risk employees.
- Monitor campaign completion.
- Generate security reports.
- Review AI-generated recommendations.
- Monitor overall platform health.

Rather than functioning only as a reporting interface, the dashboard also serves as the operational control center for the entire platform.

Dashboard Workflow

The dashboard continuously retrieves information from multiple backend modules.



The dashboard automatically updates whenever new phishing events are recorded or risk calculations are performed.

Dashboard Components

The dashboard consists of several independent information panels.

Each panel displays information generated by a different backend module.

Employee Management Panel

Purpose

Displays information about every employee participating in phishing awareness campaigns.

The administrator can quickly determine:

- Employee Name
- Employee ID
- Department
- Email Address
- Current Campaign Status
- Risk Level
- Risk Score
- Target Goal

The information displayed in this section is retrieved directly from the employee database together with campaign history and risk calculations.

This allows administrators to monitor employee progress without manually querying the database.

Campaign Monitoring Panel

Purpose

Displays information about all phishing campaigns currently managed by the platform.

Typical information includes:

- Campaign Name
- Campaign Identifier
- Campaign Status
- Number of Employees
- Campaign Start Time
- Campaign Completion Status

Administrators can monitor campaign progress throughout its lifecycle.

As employee interactions are recorded, campaign statistics are updated automatically.

Employee Status Monitoring

The dashboard continuously monitors employee campaign progress.

Typical employee states include:

Status	Meaning
Pending	Employee has not yet interacted with the campaign.
Email Opened	Tracking image detected.
Link Clicked	Employee clicked the phishing link.
Credentials Submitted	Employee entered credentials.
Campaign Completed	Target objective achieved.

These status indicators allow administrators to observe campaign progress in real time.

Risk Dashboard

Purpose

Displays employee cybersecurity risk.

The dashboard presents information such as:

- Risk Score
- Risk Level
- Employee Ranking
- Risk Percentile

Rather than requiring administrators to understand mathematical formulas,

the dashboard converts numerical calculations into clear visual indicators.

Example:

Employee	Score	Level
Employee A	82	CRITICAL
Employee B	48	HIGH
Employee C	27	MEDIUM

This enables rapid identification of employees requiring additional awareness training.

Department Risk Panel

The platform also evaluates cybersecurity awareness at the departmental level.

Instead of displaying only individual employees,

the dashboard aggregates employee scores into department-wide risk values.

Typical departments include:

- Human Resources
- Finance
- Information Technology
- Cyber Security
- Management

This enables administrators to determine which departments require additional phishing awareness campaigns.

Campaign Analytics

The dashboard provides statistical information regarding phishing campaign performance.

Examples include:

- Total Campaigns
- Active Campaigns
- Completed Campaigns
- Successful Simulations
- Campaign Success Rate

These statistics help administrators evaluate the effectiveness of awareness programmes over time.

AI Recommendation Panel

The platform automatically generates security recommendations based on employee behaviour.

Recommendations may include:

- Schedule mandatory awareness training.
- Increase phishing simulation frequency.
- Conduct department-specific training.
- Improve email filtering.
- Review privileged account access.

Recommendations are generated using calculated employee risk rather than generic organizational advice.

This allows administrators to focus remediation efforts where they are most needed.

Security Activity Feed

The dashboard continuously displays important security events occurring within the platform.

Examples include:

- Administrator Login
- Campaign Started
- Email Delivered
- Email Opened
- Link Clicked
- Credentials Submitted
- Account Locked
- Brute Force Detection

This activity feed provides administrators with immediate visibility into ongoing platform operations.

Enterprise Risk Summary

The dashboard also presents an organization-wide cybersecurity summary.

Typical indicators include:

- Total Employees
- Employees at Critical Risk
- Employees at High Risk
- Employees at Medium Risk
- Employees at Low Risk
- Overall Organizational Risk

These indicators enable executive management to assess the cybersecurity posture of the organization at a glance.

Platform Health Monitoring

The dashboard includes a health monitoring section that verifies the operational status of core platform components.

Typical health checks include:

- Database Connectivity
- AI Engine Availability
- SMTP Server Status
- Event Tracking Status
- Campaign Engine Status

If any critical component becomes unavailable, the dashboard immediately reflects the issue so that corrective action can be taken.

This functionality supports continuous availability of the platform.

Real-Time Updates

The dashboard has been designed to display current information rather than static reports.

Whenever an employee:

- Opens an email,
- Clicks a phishing link,
- Submits credentials,
- Completes a campaign,

the relevant dashboard panels are updated after the backend processes the new event.

This ensures that administrators are always working with current information.

Benefits of the Dashboard

The Administrator Dashboard provides several operational benefits:

- Centralizes cybersecurity monitoring.
 - Displays real-time phishing campaign status.
 - Identifies high-risk employees.
 - Compares departmental cybersecurity awareness.
 - Displays AI-generated recommendations.
 - Supports executive reporting.
 - Simplifies campaign management.
 - Provides visibility into platform health.
 - Reduces the need for manual database analysis.
-

Chapter Summary

The Administrator Dashboard serves as the operational command center of the AI-Powered Phishing Awareness & Training Platform. By combining campaign monitoring, employee risk assessment, departmental analytics, security activity, AI-generated recommendations, and platform health information into a single interface, it enables administrators to monitor, manage, and improve organizational cybersecurity awareness efficiently.

Chapter 16: Flask Routes and API Documentation

16.1 Overview

The AI-Powered Phishing Awareness & Training Platform is built using the Flask web framework. Flask acts as the communication layer between users, administrators, the database, the Artificial Intelligence Engine, and the Risk Assessment Engine.

Whenever a user performs an action, such as logging into the administrator portal, sending a phishing campaign, opening a phishing email, clicking a phishing link, or submitting credentials, the browser sends an HTTP request to the Flask application.

The Flask application receives the request, processes the required business logic, communicates with supporting modules, interacts with the PostgreSQL database, and finally returns an appropriate response to the user.

Each request is handled by a dedicated Flask Route.

A Flask Route defines:

- Which URL should respond to the request.
- Which HTTP method is permitted.
- Which backend function should execute.
- Which database operations should occur.
- Which HTML page or JSON response should be returned.

Together, these routes form the Application Programming Interface (API) of the platform.

Purpose of Flask Routes

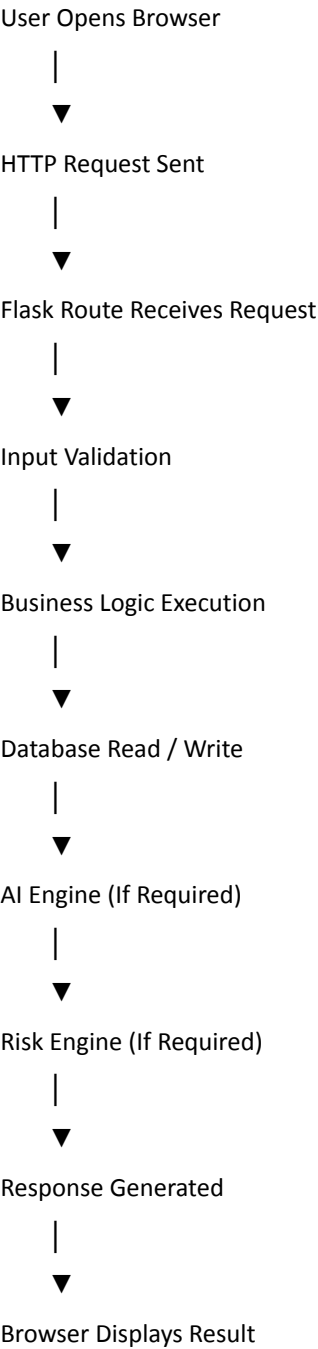
The routing layer performs several important responsibilities.

- Receives requests from users.
- Authenticates administrators.
- Creates phishing campaigns.
- Invokes the AI Engine.
- Sends phishing emails.
- Records employee interactions.
- Updates campaign status.
- Calculates employee risk.
- Retrieves dashboard information.
- Generates reports.
- Returns HTML pages or JSON responses.

Without Flask Routes, none of the application modules would be accessible through the web interface.

Route Processing Workflow

Every request follows the same processing lifecycle.



HTTP Methods Used

The platform primarily uses two HTTP methods.

GET

GET requests retrieve information from the application.

Typical examples include:

- Opening web pages.

- Viewing employee information.
- Displaying reports.
- Opening phishing pages.
- Tracking email opens.
- Tracking link clicks.

GET requests generally do not require users to submit large amounts of data.

POST

POST requests send information to the server.

Typical examples include:

- Administrator login.
- Campaign creation.
- Email generation.
- Credential submission.
- Report generation.

POST requests are generally used whenever data needs to be stored or updated.

Route Categories

For easier maintenance, the routes used by the platform can be grouped into functional categories.

1. Authentication Routes

These routes manage administrator authentication and access control.

Typical operations include:

- Administrator login.
 - Session creation.
 - Logout.
 - Account protection.
-

2. Campaign Management Routes

These routes manage phishing campaigns.

Typical operations include:

- Create campaign.
 - Select employees.
 - Generate phishing emails.
 - Send emails.
 - Update campaign status.
-

3. Employee Interaction Routes

These routes monitor employee behaviour.

Typical operations include:

- Email opened.
 - Link clicked.
 - Credential submitted.
 - Campaign completed.
-

4. Dashboard Routes

These routes provide information displayed on the administrator dashboard.

Examples include:

- Employee list.
 - Risk scores.
 - Campaign statistics.
 - Department analytics.
 - Reports.
-

5. Report Routes

These routes generate reports for administrators.

Typical reports include:

- Employee Risk Report.
 - Department Report.
 - Campaign Report.
 - Monthly Report.
-

6. AI Routes

These routes communicate with the Artificial Intelligence Engine.

Responsibilities include:

- Generate phishing email.
 - Validate generated campaign.
 - Regenerate email if validation fails.
-

7. Security Routes

These routes perform security-related functions.

Examples include:

- Administrator authentication.
 - Brute-force detection.
 - Security alerts.
 - Credential verification.
-

General Route Lifecycle

Although each route performs a different task, almost every route follows the same sequence of operations.

Step 1

Receive the HTTP request.

Step 2

Validate user input.

Step 3

Verify administrator session if required.

Step 4

Retrieve required information from PostgreSQL.

Step 5

Invoke supporting modules such as:

- AI Engine
 - Campaign Validator
 - Risk Engine
 - Event Tracker
-

Step 6

Update the database if necessary.

Step 7

Generate HTML or JSON response.

Step 8

Return the response to the browser.

Error Handling

Every route performs basic error handling before returning a response.

Typical situations include:

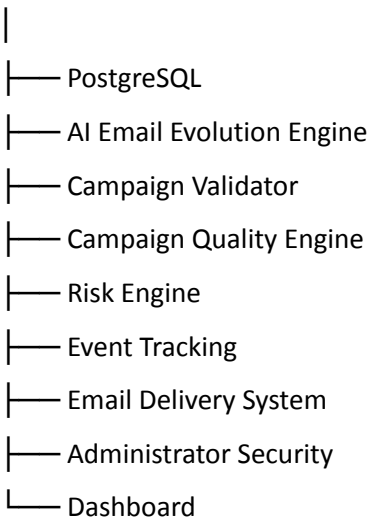
- Invalid user input.
- Database connection failure.
- AI service unavailable.
- Email delivery failure.
- Campaign validation failure.
- Employee not found.
- Unauthorized administrator access.

Whenever possible, the application logs the error and returns an appropriate response instead of terminating unexpectedly.

Relationship with Other Modules

The Flask routing layer communicates with almost every component of the platform.

Flask Routes



The routes themselves contain very little business logic.

Instead, they act as controllers that coordinate communication between specialized backend modules.

Chapter Summary

The Flask routing layer serves as the communication backbone of the AI-Powered Phishing Awareness & Training Platform. It receives all incoming requests, coordinates backend processing, interacts with the database and AI components, and returns responses to users. By separating routing from business logic, the application remains modular, maintainable, and easier for future developers to extend.

16.2 Authentication Routes

Overview

Authentication is the first layer of security implemented within the AI-Powered Phishing Awareness & Training Platform.

Since the platform provides access to confidential employee information, phishing campaign history, cybersecurity risk reports, Artificial Intelligence configuration, and organizational dashboards, unrestricted access could result in significant security risks.

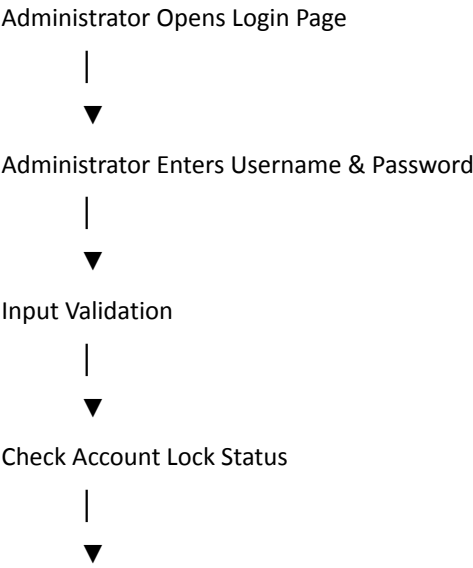
The Authentication Module ensures that only authorized administrators are permitted to access the management portal.

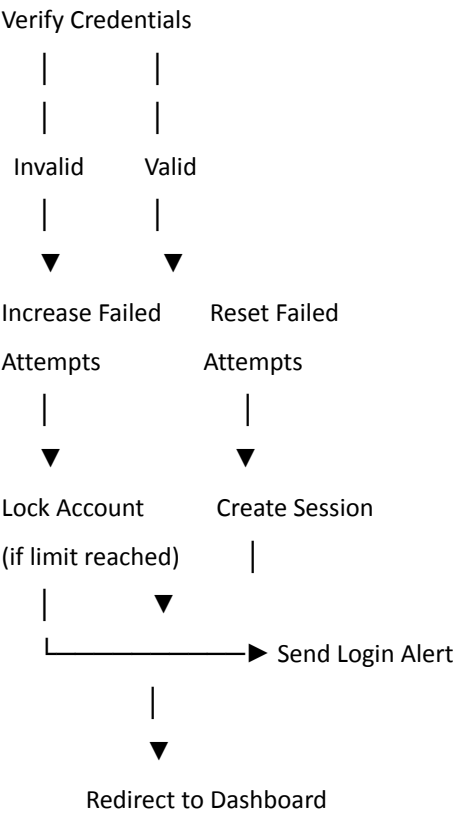
In addition to verifying administrator credentials, the module also implements multiple security controls, including brute-force protection, administrator login alerts, session management, and account lockout.

Together, these mechanisms protect the administrative interface from unauthorized access.

Authentication Workflow

The administrator authentication process follows the sequence illustrated below.





Route 1 – Administrator Login Page

Route

/

(If your application uses `/admin-login` or another URL as the initial page, replace this accordingly.)

HTTP Method

GET

Purpose

This route displays the administrator login page.

It is the first page accessed when the application starts.

The page allows administrators to enter their username and password before accessing any protected functionality.

Processing Steps

When this route is accessed:

1. Flask receives the request.
 2. Administrator session is checked.
 3. If already authenticated, the administrator may be redirected directly to the dashboard.
 4. Otherwise, the login page is displayed.
-

Database Access

None.

Output

Returns the administrator login page.

Route 2 – Administrator Login

Route

POST /login

(Replace with the actual route used inside `app.py`.)

HTTP Method

POST

Purpose

Authenticates the administrator.

This route processes the username and password entered on the login page.

Input Parameters

Parameter	Description
Username	Administrator username
Password	Administrator password

Processing Steps

The login process consists of multiple validation stages.

Step 1

Receive administrator credentials.

Step 2

Validate that both username and password have been provided.

Step 3

Check whether the administrator account is currently locked.

This verification is performed using the Brute Force Protection module.

If the account is locked,

authentication immediately stops.

Step 4

Verify administrator credentials.

If authentication succeeds:

- failed login attempts are reset
- administrator session is created
- login alert email is generated
- administrator is redirected to the dashboard

Step 5

If authentication fails:

- failed attempt counter increases
- remaining attempts decrease
- if maximum attempts are exceeded,
account is temporarily locked

Modules Used

- `bruteforce_service.py`
- `admin_alert_service.py`

Database Tables Used

`login_attempts`

Output

Successful authentication:

Administrator Dashboard

Failed authentication:

Login Page

+

Error Message

Brute Force Protection

Before password verification begins,

the platform determines whether the administrator account has already been locked.

The Brute Force Protection module performs this verification automatically.

If the account is locked,

authentication immediately terminates.

No password verification occurs.

This prevents automated password guessing attacks.

Failed Login Handling

Every failed login attempt updates the administrator's security record.

The following information is maintained:

- Username
- Failed Attempt Count
- Lock Expiration Time

When the failed attempt count reaches the configured maximum,

the platform automatically locks the administrator account.

The lock remains active for the configured lock duration.

During this period,

all authentication requests are rejected.

Successful Login Handling

When authentication succeeds,

the platform performs several additional operations.

These include:

- Reset failed login counter.
- Remove temporary account lock.
- Create administrator session.

- Generate administrator login notification.
- Redirect administrator to dashboard.

These operations occur automatically after successful authentication.

Administrator Login Notification

Every successful login generates an email notification.

The notification contains:

- Administrator Username
- Login Time
- Source IP Address
- Login Status

This feature enables rapid detection of unauthorized administrator access.

If an administrator receives an unexpected login notification,

they can immediately investigate potential account compromise.

Account Lock Notification

If repeated failed login attempts exceed the configured threshold,

the platform generates a critical security alert.

The notification contains:

- Username
- Failed Attempt Count
- Detection Time
- Source IP Address
- Lock Duration

This allows administrators to respond quickly to potential brute-force attacks.

Session Management

After successful authentication,

Flask creates a secure administrator session.

The session remains active until:

- Administrator logs out.
- Session expires.
- Browser session ends.

Protected routes verify the existence of this session before allowing access.

If no valid session exists,

the administrator is redirected to the login page.

Security Features

The Authentication Module includes multiple security controls.

Credential Verification

Ensures only valid administrator credentials are accepted.

Brute Force Protection

Blocks repeated password guessing attacks.

Automatic Account Locking

Temporarily disables compromised accounts.

Login Notifications

Immediately informs administrators about successful logins.

Session Security

Protects administrative pages from unauthorized access.

Audit Logging

Maintains administrator authentication history.

Error Conditions

The Authentication Module can return several different outcomes.

Situation	Response
Missing Username	Display validation error
Missing Password	Display validation error
Incorrect Credentials	Increase failed attempt counter
Maximum Attempts Exceeded	Lock administrator account
Account Already Locked	Deny login
Successful Authentication	Redirect to dashboard

Chapter Summary

The Authentication Module provides secure access to the administrative functions of the AI-Powered Phishing Awareness & Training Platform. It combines credential verification, brute-force protection, automated account locking, administrator notifications, and session management to ensure that only authorized personnel can access sensitive organizational information. By integrating multiple security controls into the authentication process, the platform reduces the risk of unauthorized administrative access while maintaining usability for legitimate users.

16.3 Dashboard Routes

Overview

The Dashboard Routes provide all information displayed on the Administrator Dashboard.

Whenever an administrator opens the dashboard, refreshes a page, views employee information, checks campaign statistics, reviews risk scores, or generates reports, the request is processed through one of these routes.

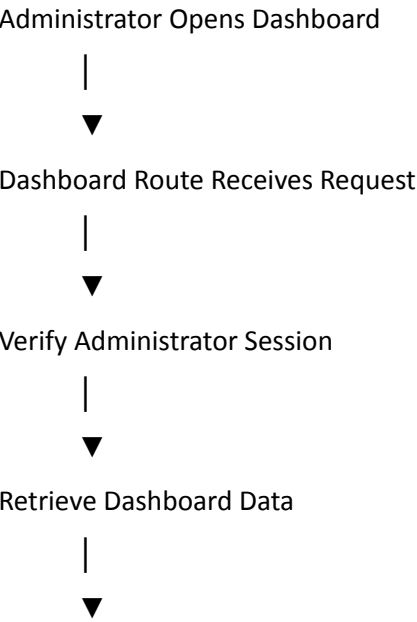
Unlike Authentication Routes, which focus on user verification, Dashboard Routes focus on retrieving organizational information from the backend and presenting it in a meaningful format.

These routes collect data from multiple modules, including:

- Employee Database
- Campaign Management
- Event Tracking
- Risk Assessment Engine
- AI Recommendation Engine
- System Health Monitor
- Reporting Engine

The retrieved information is then displayed using HTML templates or returned as JSON for dynamic dashboard updates.

Dashboard Workflow



Employee Information
Campaign Statistics
Risk Scores
Department Analytics
Security Events
System Health



Prepare Dashboard Objects



Render HTML Template



Dashboard Displayed

Route 1 – Dashboard Home

Route

/dashboard

(Replace with the actual route name used in your application.)

HTTP Method

GET

Purpose

Displays the main administrator dashboard.

This page acts as the central control panel of the application.

After successful administrator authentication, users are redirected to this page.

Processing Steps

The dashboard performs several operations before displaying information.

Step 1

Verify administrator session.

Step 2

Retrieve employee information.

Step 3

Retrieve campaign information.

Step 4

Calculate employee risk.

Step 5

Calculate department statistics.

Step 6

Load AI recommendations.

Step 7

Check system health.

Step 8

Render dashboard page.

Information Displayed

The dashboard normally contains:

- Total Employees
- Active Campaigns
- Completed Campaigns
- High Risk Employees
- Department Statistics
- AI Recommendations
- Security Alerts
- Platform Health

Database Tables Used

- employees
- campaign_runs
- campaign_targets
- simulation_logs
- prompt_history

Output

Administrator Dashboard Page

Route 2 – Employee Dashboard

Purpose

Displays detailed employee information.

Each employee displayed on the dashboard contains:

- Employee ID
- Name

- Email
- Department
- Target Goal
- Campaign Status
- Risk Level
- Risk Score

The administrator can quickly identify which employees have completed phishing simulations and which employees require further awareness training.

Employee Status Calculation

The dashboard determines employee status using recorded phishing events.

Possible values include:

Status	Meaning
Pending	Employee has not interacted with campaign
Email Opened	Tracking pixel detected
Link Clicked	Employee clicked phishing link
Credential Submitted	Employee entered credentials
Completed	Campaign objective achieved

These values are updated automatically whenever new phishing events are recorded.

Route 3 – Campaign Dashboard

Purpose

Displays phishing campaign information.

Typical campaign information includes:

- Campaign Name
- Campaign ID

- Campaign Status
- Campaign Start Time
- Campaign Completion
- Number of Employees
- Success Rate

Administrators can monitor campaign progress without accessing the database.

Campaign Status

Campaigns generally move through the following stages.

Created



Running



Employees Receiving Emails



Interactions Recorded



Completed

The dashboard updates campaign status automatically.

Route 4 – Employee Risk Dashboard

Purpose

Displays cybersecurity awareness scores.

The dashboard retrieves employee risk calculations from the Risk Assessment Engine.

Each employee record displays:

- Risk Score
- Risk Level
- Risk Rank
- Risk Percentile

Example

Employee	Score	Level
Rahul	82	CRITICAL
Priya	57	HIGH
Amit	28	MEDIUM
Karan	8	LOW

These values help administrators prioritize awareness training.

Route 5 – Department Analytics

Purpose

Displays cybersecurity awareness at department level.

Instead of viewing employees individually,
administrators can compare entire departments.

Typical departments include:

- Human Resources
- Finance
- Information Technology
- Cyber Security
- Management

Department scores are calculated by combining:

- Average Employee Risk
- Maximum Employee Risk

This provides a balanced view of departmental cybersecurity posture.

Route 6 – AI Recommendation Dashboard

Purpose

Displays recommendations automatically generated by the platform.

Recommendations are based upon:

- Employee Risk Score
- Department
- Previous Behaviour
- Campaign Performance

Typical recommendations include:

- Conduct awareness session.
- Increase phishing frequency.
- Deploy targeted campaigns.
- Review privileged users.
- Perform additional monitoring.

These recommendations help administrators determine the next cybersecurity action.

Route 7 – Security Activity Feed

Purpose

Displays recent security events.

Examples include:

- Administrator Login
- Campaign Created
- Campaign Completed

- Email Delivered
- Email Opened
- Link Clicked
- Credential Submitted
- Brute Force Detection

The activity feed gives administrators immediate visibility into platform activity.

Route 8 – System Health Dashboard

Purpose

Displays operational status of the application.

The dashboard verifies the health of several platform components.

Typical health checks include:

- PostgreSQL Database
- Gemini AI Service
- SMTP Mail Server
- Event Tracking System
- Risk Engine
- Campaign Engine

Each service is displayed as either:

- Healthy
- Warning
- Critical

This enables administrators to identify operational problems before they affect phishing campaigns.

Dynamic Dashboard Updates

Many dashboard components refresh automatically.

Instead of reloading the complete page,

specific information such as:

- Campaign Statistics
- Risk Scores
- Employee Status
- Security Activity

can be updated independently.

This improves responsiveness and reduces unnecessary server load.

Data Sources

Every dashboard component retrieves information from a different backend module.

Dashboard Widget	Source
Employee List	Employee Database
Campaign Statistics	Campaign Management Module
Risk Scores	Risk Assessment Engine
Department Scores	Department Risk Module
Recommendations	AI Recommendation Engine
Security Feed	Event Tracking System
Health Status	System Health Module

This modular design allows each backend component to evolve independently without requiring changes to the entire dashboard.

Error Handling

Dashboard routes perform several validation checks before displaying information.

Possible situations include:

Situation	Action
Database unavailable	Display error message
Administrator session expired	Redirect to login
No campaigns available	Display empty dashboard
No employees found	Display informational message
AI unavailable	Continue without recommendations
SMTP unavailable	Display service warning

The dashboard is designed to remain operational even if one supporting module becomes temporarily unavailable.

Benefits of Dashboard Routes

The Dashboard Routes provide several operational advantages.

- Centralize cybersecurity monitoring.
 - Present real-time organizational information.
 - Reduce manual database queries.
 - Integrate multiple backend modules.
 - Display employee and department risk.
 - Present AI-generated recommendations.
 - Monitor platform health.
 - Improve administrator decision-making.
-

Chapter Summary

The Dashboard Routes act as the presentation layer of the platform. They collect information from the Employee Database, Campaign Management Layer, Risk Assessment Engine, Event Tracking System, and AI Recommendation Engine, then organize that information into an intuitive interface for administrators. By consolidating operational, analytical, and security information into a single dashboard, these routes enable efficient management of phishing awareness campaigns and provide a comprehensive view of the organization's cybersecurity posture.

16.4 Campaign Management Routes

Overview

The Campaign Management Routes control the complete lifecycle of a phishing simulation campaign.

These routes coordinate communication between the administrator, Artificial Intelligence Engine, Campaign Validation Engine, Email Delivery System, Event Tracking System, and PostgreSQL database.

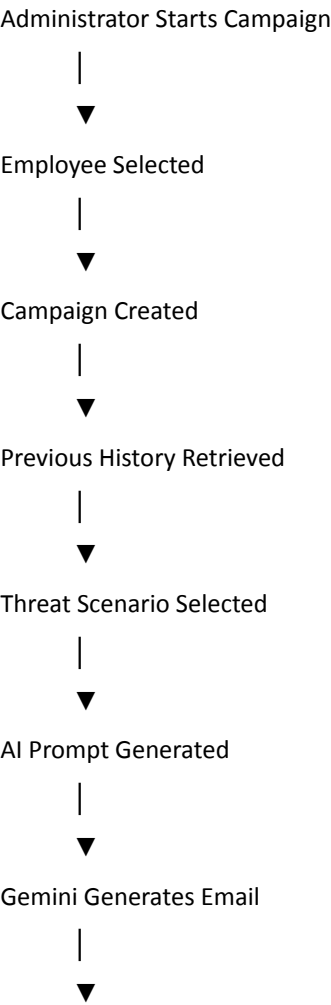
Whenever an administrator starts a phishing simulation, every operation passes through these routes.

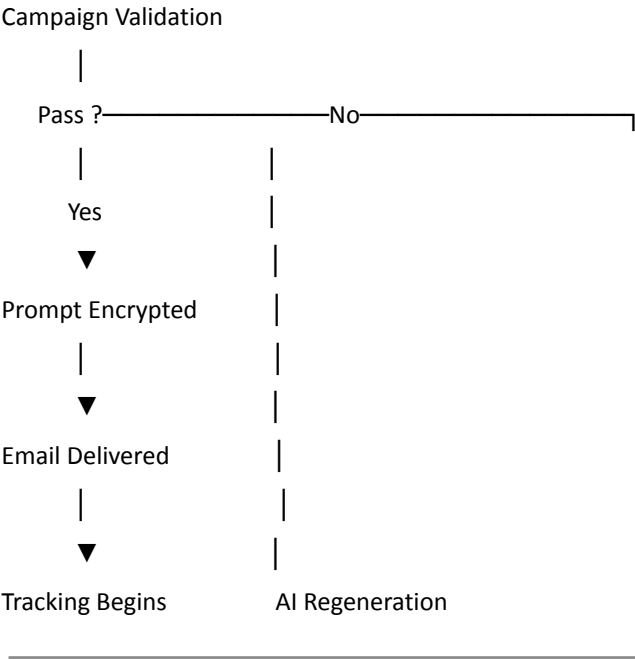
Unlike the Dashboard Routes, which primarily retrieve information, Campaign Management Routes actively create, modify, validate, and monitor phishing campaigns.

These routes represent the operational core of the entire platform.

Campaign Processing Workflow

Every phishing campaign follows the workflow shown below.





Purpose of Campaign Routes

The Campaign Management Routes perform several responsibilities.

- Create phishing campaigns.
- Register campaign participants.
- Generate AI prompts.
- Invoke Google Gemini.
- Validate generated emails.
- Encrypt campaign history.
- Deliver phishing emails.
- Monitor employee interaction.
- Update campaign progress.
- Close completed campaigns.

Without these routes, administrators would be unable to launch phishing awareness campaigns.

Route 1 – Create Campaign

Route

/create-campaign

(Replace with the actual route used in your application.)

HTTP Method

POST

Purpose

Creates a new phishing awareness campaign.

When an administrator initiates a campaign, the platform first creates a campaign record before any emails are generated.

This campaign acts as the parent record for every employee participating in the simulation.

Input Parameters

Typical inputs include:

Parameter	Description
Campaign Name	Name of phishing campaign
Trigger Mode	Manual or Automatic
Notes	Additional campaign description

Processing Steps

The route performs the following operations.

Step 1

Receive campaign details.

Step 2

Create campaign record.

Step 3

Generate Campaign ID.

Step 4

Store campaign inside PostgreSQL.

Step 5

Return Campaign Identifier.

Every employee processed afterwards is associated with this Campaign ID.

Route 2 – Employee Selection

Purpose

Associates employees with the newly created phishing campaign.

The administrator may choose:

- Individual employee
- Multiple employees
- Entire department
- Entire organization

For every selected employee,

the platform creates a campaign target record.

Information Stored

For each employee the following information is recorded:

- Campaign ID
- Employee ID
- Employee Name
- Email

- Department
- Target Goal
- Campaign Status
- Attempt Number

This creates a permanent relationship between employees and campaigns.

Route 3 – Retrieve Campaign History

Purpose

Before generating a phishing email,

the platform retrieves historical information about the employee.

The retrieved information includes:

- Previous phishing campaigns.
- Previous AI prompts.
- Previous subjects.
- Previous Call-To-Action phrases.
- Previous sender identities.
- Previous scenarios.
- Previous campaign outcomes.

This information is passed to the AI Email Evolution Engine.

The objective is to prevent repetition.

Route 4 – Threat Scenario Selection

Purpose

Selects the most appropriate phishing scenario.

The selection depends upon:

- Employee department.
- Previously used scenarios.

- Organization-wide successful scenarios.
- AI strategy.

Examples include:

Human Resources

- Payroll Update
- Attendance Review
- Benefits Enrollment

Finance

- Vendor Invoice
- Expense Reimbursement
- Tax Declaration

Information Technology

- Password Expiry
- VPN Renewal
- Software License

Each department receives scenarios appropriate to its business activities.

Route 5 – AI Prompt Generation

Purpose

Constructs the instruction submitted to Google Gemini.

Rather than requesting:

Write a phishing email.

the platform constructs a detailed prompt containing:

- Employee Name
- Department
- Designation
- Previous Behaviour
- Previous Subjects

- Previous CTAs
- Previous Campaigns
- Current Strategy
- Selected Scenario

This additional context significantly improves the quality of AI-generated phishing emails.

Route 6 – AI Email Generation

Purpose

Generates phishing content.

The route submits the generated prompt to Gemini AI.

Gemini returns:

- Email Subject
- Email Body

The platform then:

- Cleans the response.
- Formats HTML.
- Removes unwanted characters.
- Standardizes spacing.

The generated email is now ready for validation.

Route 7 – Campaign Validation

Purpose

Ensures that every generated phishing campaign satisfies organizational quality standards.

Validation includes:

- Subject Similarity
- Body Similarity
- CTA Similarity

- Sender Diversity
- Scenario Reuse

If validation succeeds,

processing continues.

If validation fails,

the Campaign Quality Engine prepares regeneration instructions.

The AI then generates another phishing email.

This cycle continues until validation succeeds or the retry limit is reached.

Route 8 – Campaign Encryption

Purpose

Protects generated campaign information.

Before storing campaign history,

the platform encrypts:

- AI Prompt
- Subject
- Email Body
- Scenario
- Sender
- CTA
- Employee Information

Only encrypted data is written into PostgreSQL.

This protects campaign confidentiality.

Route 9 – Email Delivery

Purpose

Delivers the phishing email.

The Email Delivery System performs several operations.

Step 1

Generate personalized HTML email.

Step 2

Generate tracking links.

Step 3

Insert invisible tracking image.

Step 4

Insert corporate signature.

Step 5

Insert legal disclaimer.

Step 6

Authenticate with SMTP.

Step 7

Deliver email.

Every employee receives an individualized phishing simulation.

Route 10 – Campaign Monitoring

Purpose

Monitors campaign progress.

During campaign execution,

employee interactions are continuously recorded.

Typical interactions include:

- Email Opened
- Link Clicked
- Credentials Submitted

Campaign status changes automatically based upon employee behaviour.

Route 11 – Campaign Completion

Purpose

Marks campaigns as completed.

Campaign completion occurs when:

- Employee achieves campaign objective.
- Campaign expires.
- Administrator manually closes campaign.

The platform updates:

- Campaign Status
- Employee Status
- Achievement Time
- Campaign Statistics

Completed campaigns remain available for reporting and future AI learning.

Database Tables Used

The Campaign Management Routes interact with several database tables.

Table	Purpose
campaign_runs	Stores campaign information
campaign_targets	Stores employee participation
prompt_history	Stores encrypted AI prompts
simulation_logs	Stores employee interactions
employees	Employee information

These tables collectively maintain the complete phishing campaign lifecycle.

Error Handling

The Campaign Management Routes handle several possible failures.

Situation	Action
Employee not found	Stop processing
Campaign creation failed	Display error
AI unavailable	Retry or display failure
Validation failed	Regenerate campaign
SMTP unavailable	Abort email delivery
Database unavailable	Roll back transaction
Encryption failure	Prevent storage

This ensures that incomplete or inconsistent campaign data is not stored.

Security Controls

Several security mechanisms protect campaign execution.

Encryption

All AI-generated campaign information is encrypted before storage.

Validation

Every AI-generated email must pass quality checks before delivery.

Audit Trail

Every campaign receives a unique Campaign ID.

Prompt History

Historical prompts are securely stored for future AI learning.

Employee Isolation

Each employee receives a personalized phishing campaign.

Benefits of Campaign Management Routes

The Campaign Management Routes provide several operational advantages.

- Automate the phishing campaign lifecycle.
- Prevent repetitive phishing simulations.
- Personalize campaigns for every employee.
- Maintain complete campaign history.
- Support AI-driven phishing evolution.
- Secure campaign information through encryption.
- Integrate directly with email delivery and event tracking.
- Maintain complete auditability.

Chapter Summary

The Campaign Management Routes coordinate every stage of a phishing awareness campaign, from initial creation through AI generation, validation, secure storage, email delivery, and campaign completion. By integrating the Artificial Intelligence Engine, Campaign Validation Engine, Encryption Layer, Email Delivery System, and Event Tracking System into a single workflow, these routes enable the platform to deliver adaptive, secure, and measurable phishing simulations while maintaining a complete historical record for future learning and analysis.

16.5 Employee Interaction & Tracking Routes

Overview

The Employee Interaction & Tracking Routes monitor employee behaviour after a phishing email has been delivered.

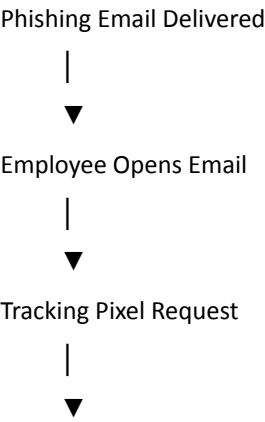
These routes represent one of the most important components of the platform because they provide the behavioural data used throughout the system.

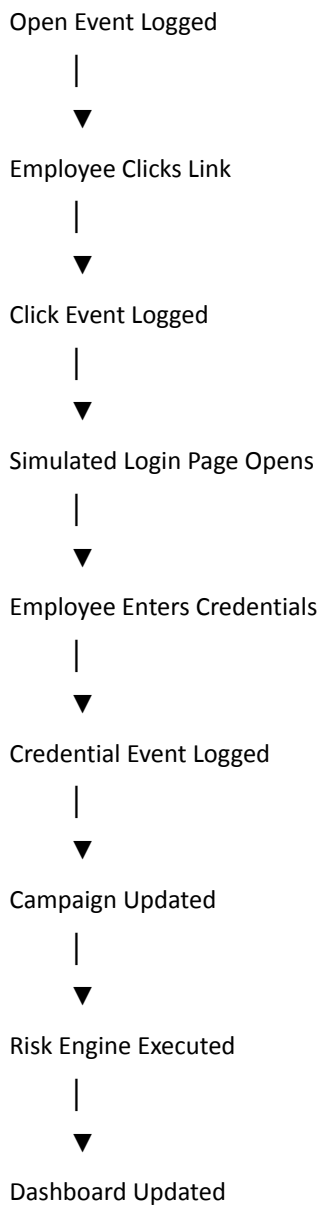
Every employee action—from opening an email to submitting credentials—is captured through these routes.

The collected information is securely stored, associated with the corresponding phishing campaign, and later processed by the Risk Assessment Engine to calculate cybersecurity awareness scores.

Without these routes, the platform would only know that an email was sent. It would have no visibility into how employees responded to the phishing simulation.

Interaction Workflow





Purpose of Interaction Routes

These routes perform several responsibilities.

- Detect email opening.
- Detect phishing link clicks.
- Display phishing landing pages.
- Capture simulated credentials.
- Record employee behaviour.
- Update campaign progress.
- Trigger risk calculations.
- Maintain campaign history.
- Supply live dashboard updates.

Together, these routes provide the behavioural intelligence that drives the entire phishing awareness platform.

Route 1 – Email Open Tracking

Route

/track-open

(Replace with the actual route defined in your application.)

HTTP Method

GET

Purpose

Records when an employee opens a phishing email.

This route is triggered automatically through an invisible tracking image embedded inside every HTML email.

The employee is usually unaware that this request has occurred.

Processing Steps

When the email client loads the tracking image:

Step 1

Receive tracking request.

Step 2

Identify:

- Employee
 - Campaign
 - Prompt Version
-

Step 3

Create IMAGE event.

Step 4

Store encrypted event.

Step 5

Return tracking image.

The employee experiences no interruption while the system records the interaction.

Event Generated

IMAGE

This event indicates that the phishing email has been opened.

Route 2 – Link Click Tracking

Route

/track-click

HTTP Method

GET

Purpose

Records when an employee clicks the phishing hyperlink contained within the email.

Unlike the tracking pixel,

this interaction represents active employee engagement with the phishing simulation.

Processing Steps

When the employee clicks the phishing button:

Step 1

Receive tracking request.

Step 2

Verify campaign identifiers.

Step 3

Create LINK event.

Step 4

Update campaign progress.

Step 5

Redirect employee to simulated phishing page.

The employee experiences a normal webpage redirect while the interaction is recorded.

Event Generated

LINK

Route

/login

(Replace with the phishing landing page route used by your project.)

HTTP Method

GET

Purpose

Displays the simulated credential capture page.

The page resembles a legitimate organizational login portal.

Typical examples include:

- Employee Portal
- HR Portal
- Microsoft 365 Login
- VPN Authentication
- Internal Application Login

The purpose is to evaluate whether employees recognise the phishing attempt.

Information Displayed

The simulated login page generally contains:

- Organization Logo
- Username Field
- Password Field
- Login Button
- Corporate Branding

Although visually realistic,

the page exists solely for awareness training.

Route 4 – Credential Submission

Route

/login

(POST request on the simulated login page.)

HTTP Method

POST

Purpose

Records that credentials were entered into the phishing simulation.

The platform does **not** use the submitted credentials for authentication.

Instead,

the submission itself is treated as the phishing event.

Processing Steps

Step 1

Receive submitted username.

Step 2

Receive submitted password.

Step 3

Associate submission with:

- Employee
- Campaign

- Prompt Version
-

Step 4

Create CREDENTIAL event.

Step 5

Store encrypted interaction.

Step 6

Update campaign status.

Step 7

Display awareness message or completion page.

Event Generated

CREDENTIAL

This event contributes the highest value during risk calculation because credential disclosure represents the most severe phishing outcome in the current simulation model.

Route 5 – Event Logging

Purpose

Every interaction route eventually calls the Event Logging module.

The Event Logger stores:

- Employee ID

- Campaign ID
- Prompt Version
- Event Type
- Payload Type
- Timestamp
- Department
- Risk Contribution

The complete record is encrypted before storage.

This creates a permanent audit trail for future analysis.

Route 6 – Campaign Status Update

After every interaction,

the campaign status is automatically recalculated.

Possible campaign states include:

Status	Description
Pending	No interaction detected
Opened	Email opened
Clicked	Link clicked
Credentials Captured	Credentials submitted
Completed	Campaign objective achieved

These values are immediately reflected on the administrator dashboard.

Route 7 – Risk Engine Trigger

After recording a new interaction,

the platform immediately invokes the Risk Assessment Engine.

The Risk Engine:

- Reads event history.
- Updates event counts.
- Calculates new risk score.
- Determines risk level.
- Updates employee ranking.
- Calculates percentile.
- Synchronizes results with PostgreSQL.

This ensures that dashboard information always reflects the latest employee behaviour.

Route 8 – Dashboard Refresh

After risk calculation,

dashboard information becomes available for refresh.

Updated information includes:

- Employee Status
- Campaign Status
- Risk Score
- Risk Level
- Department Risk
- Security Activity Feed

Administrators therefore receive current information shortly after employee interactions occur.

Database Tables Used

The Interaction Routes communicate with multiple database tables.

Table	Purpose
simulation_logs	Stores employee interaction events
employees	Employee details
campaign_targets	Campaign progress

campaign_runs	Campaign information
prompt_history	Previous phishing campaigns

Security Controls

Several security mechanisms protect employee interaction processing.

Encrypted Event Storage

Every recorded interaction is encrypted before database storage.

Campaign Validation

Events are associated only with valid campaign identifiers.

Audit Trail

Every interaction receives an accurate timestamp and campaign reference.

Personalized Tracking

Every employee receives unique tracking identifiers, preventing one employee's interactions from being confused with another's.

Controlled Risk Updates

Risk calculations occur only after validated interaction events have been successfully recorded.

Error Handling

The Interaction Routes handle several operational conditions.

Situation	System Response
Invalid Campaign ID	Reject request
Unknown Employee	Ignore interaction
Duplicate Event	Prevent duplicate logging
Database Failure	Roll back transaction
Missing Tracking Information	Display default page without recording
Risk Engine Failure	Log error and preserve recorded event

These safeguards maintain the integrity of campaign statistics and behavioural analytics.

Benefits of Employee Interaction Routes

The Employee Interaction & Tracking Routes provide several operational advantages.

- Monitor the complete phishing lifecycle.
 - Record employee behaviour automatically.
 - Support accurate cybersecurity risk calculations.
 - Maintain encrypted behavioural records.
 - Update campaigns in real time.
 - Synchronize dashboard information.
 - Create a complete audit trail.
 - Supply historical data for future AI learning.
-

Chapter Summary

The Employee Interaction & Tracking Routes form the behavioural intelligence layer of the platform. They capture every significant employee action during phishing simulations, securely record those interactions, update campaign progress, trigger risk calculations, and provide real-time information to the administrator dashboard. By linking employee behaviour directly to campaign outcomes and organizational risk metrics, these routes transform individual phishing interactions into actionable cybersecurity intelligence.

16.6 Reporting Routes

Overview

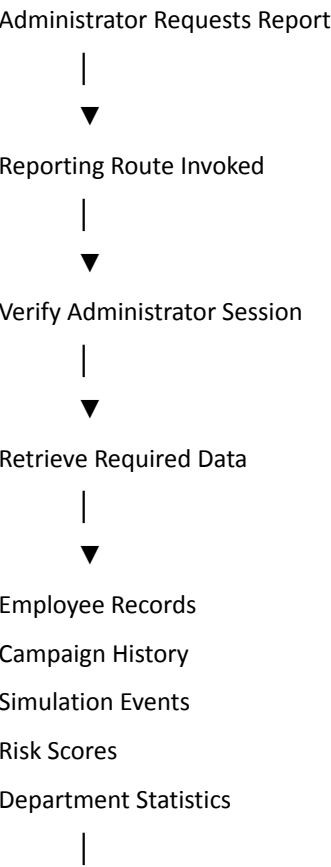
The Reporting Routes are responsible for generating cybersecurity reports from the data collected during phishing awareness campaigns.

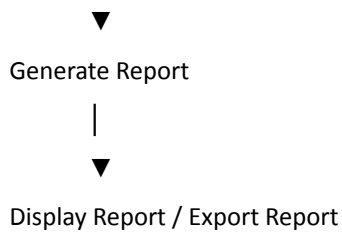
While the Administrator Dashboard displays real-time operational information, the Reporting Module transforms historical campaign data into structured reports that support management review, security audits, compliance activities, and long-term cybersecurity planning.

These reports summarize campaign performance, employee awareness levels, departmental risk, phishing trends, and organizational cybersecurity posture.

The Reporting Module retrieves information from multiple backend components, processes the data, performs statistical calculations where necessary, and presents the results in a structured format suitable for administrators and senior management.

Reporting Workflow





Purpose of Reporting Routes

The Reporting Routes perform several important functions.

- Generate campaign reports.
 - Generate employee risk reports.
 - Generate department reports.
 - Generate organizational security summaries.
 - Support executive decision-making.
 - Provide historical campaign analysis.
 - Enable cybersecurity performance measurement.
 - Support audit and compliance documentation.
-

Route 1 – Campaign Report

Route

/report/campaign

(Replace with the actual route implemented in your application.)

HTTP Method

GET

Purpose

Generates a detailed report for one or more phishing campaigns.

The report summarizes campaign execution and employee participation.

Information Included

Typical campaign reports contain:

- Campaign Name
- Campaign ID
- Campaign Duration
- Number of Employees
- Emails Delivered
- Emails Opened
- Link Clicks
- Credential Submissions
- Campaign Success Rate
- Completion Status

The report provides administrators with a complete overview of campaign performance.

Route 2 – Employee Risk Report

Purpose

Displays detailed cybersecurity awareness information for individual employees.

Each report typically includes:

- Employee Name
- Employee ID
- Department
- Risk Score
- Risk Level
- Risk Rank
- Risk Percentile
- Campaign History
- Event History

This report helps administrators identify employees who require additional awareness training.

Route 3 – Department Risk Report

Purpose

Generates cybersecurity awareness reports for each department.

Departments commonly include:

- Human Resources
- Finance
- Information Technology
- Cyber Security
- Management

The report displays:

- Number of Employees
- Average Risk
- Highest Risk Employee
- Department Risk Score
- Department Risk Level

This information helps management prioritize awareness activities across business units.

Route 4 – Organizational Security Summary

Purpose

Provides an executive-level overview of the organization's cybersecurity awareness posture.

Typical information includes:

- Total Employees
- Employees Assessed
- Active Campaigns
- Completed Campaigns
- Average Organizational Risk
- High-Risk Employees
- Critical-Risk Employees
- Overall Campaign Success Rate

This report is intended for senior management and security leadership.

Route 5 – Employee Behaviour Report

Purpose

Summarizes phishing behaviour for individual employees.

The report contains:

- Campaign Participation History
- Email Opens
- Link Clicks
- Credential Submissions
- Risk Trend
- Behaviour Pattern

Administrators can use this information to evaluate whether employee awareness is improving over time.

Route 6 – Campaign History Report

Purpose

Displays historical information for previous phishing campaigns.

The report contains:

- Campaign Timeline
- AI Scenario Used
- Sender Identity
- Target Objective
- Employee Response
- Campaign Outcome

This historical information also supports future AI campaign evolution.

Report Generation Process

Every report follows the same sequence.

Step 1

Administrator requests a report.

Step 2

Administrator authentication is verified.

Step 3

Relevant information is retrieved from PostgreSQL.

Step 4

Business logic processes the collected information.

Step 5

Statistical calculations are performed where necessary.

Examples include:

- Average Risk
 - Campaign Success Rate
 - Department Risk
 - Employee Ranking
-

Step 6

The report is formatted.

Step 7

The completed report is displayed or prepared for export.

Data Sources

The Reporting Module combines information from several backend components.

Information	Source Module
Employee Details	Employee Database
Campaign History	Campaign Management
Simulation Events	Event Tracking
Risk Scores	Risk Assessment Engine
Department Scores	Department Risk Module
AI Recommendations	Recommendation Engine

By integrating multiple sources, the reports provide a comprehensive view of organizational cybersecurity awareness.

Report Calculations

Several calculated values are included within reports.

Examples include:

Campaign Success Rate

Calculated using:

$$\frac{\text{Successful Campaigns}}{\text{Total Campaigns}} \times 100$$

Department Average Risk

Calculated using:

$$\frac{\text{Total Employee Risk}}{\text{Total Employees}}$$

Number of Employees

Employee Ranking

Employees are sorted according to calculated cybersecurity risk.

Higher scores indicate higher organizational risk.

Organizational Risk

Calculated by aggregating departmental and employee risk scores.

Security Controls

Reporting Routes implement several security controls.

Administrator Authentication

Only authenticated administrators can generate reports.

Read-Only Access

Reports retrieve information without modifying operational data.

Encrypted Data Processing

Encrypted campaign records are decrypted only when required for authorized reporting.

Auditability

Every report is generated using validated campaign and event records.

This ensures report accuracy and traceability.

Error Handling

The Reporting Module handles several operational conditions.

Situation	System Response
Administrator not authenticated	Redirect to login
Database unavailable	Display report generation error
No campaign data available	Generate empty report with notification
Employee not found	Display informative message
Risk calculation unavailable	Display partial report

These safeguards ensure stable report generation while preventing application failure.

Benefits of Reporting Routes

The Reporting Routes provide several operational advantages.

- Generate comprehensive cybersecurity reports.
 - Support executive decision-making.
 - Measure employee awareness.
 - Compare departmental cybersecurity performance.
 - Evaluate phishing campaign effectiveness.
 - Provide historical trend analysis.
 - Support security audits and compliance activities.
 - Maintain consistent reporting across the organization.
-

Chapter Summary

The Reporting Routes transform operational data into meaningful cybersecurity reports. By collecting information from the Campaign Management Layer, Event Tracking System, Risk Assessment Engine, and Employee Database, these routes provide administrators with structured insights into phishing campaign performance, employee behaviour, departmental

cybersecurity posture, and overall organizational awareness. These reports support informed decision-making, continuous improvement, and long-term cybersecurity planning.

16.7 System Health & Administrative Utility Routes

Overview

The System Health & Administrative Utility Routes are responsible for monitoring the operational status of the AI-Powered Phishing Awareness & Training Platform.

Unlike Campaign Management or Reporting Routes, these routes are not directly involved in phishing simulations. Instead, they ensure that the platform itself is functioning correctly by continuously monitoring critical services such as the database, Artificial Intelligence engine, SMTP server, event logging system, and other supporting components.

These routes enable administrators to identify operational issues before they affect phishing campaigns and provide diagnostic information for troubleshooting and maintenance.

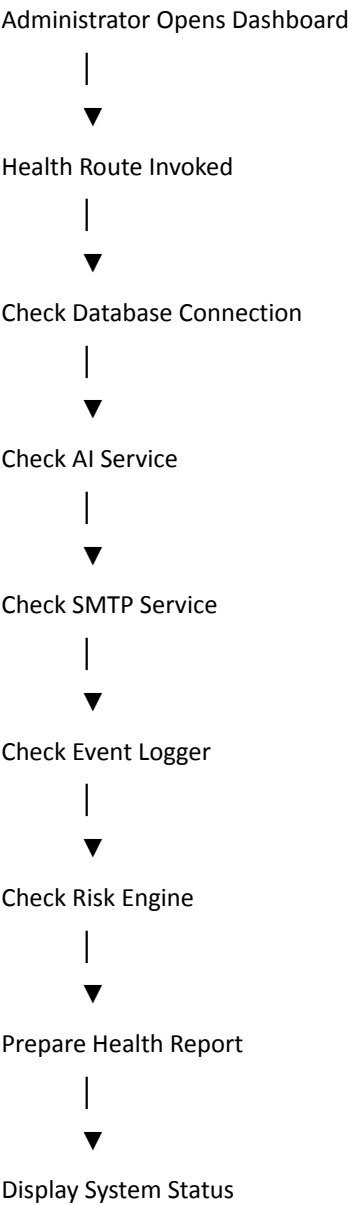
Purpose of System Health Routes

The System Health Module performs several important functions.

- Verify database connectivity.
- Monitor AI service availability.
- Verify SMTP server connectivity.
- Check event logging functionality.
- Monitor campaign engine status.
- Display platform health information.
- Support system diagnostics.
- Assist administrators during troubleshooting.

Rather than waiting for users to report problems, the platform continuously evaluates the operational status of its core components.

System Health Workflow



Route 1 – System Health Dashboard

Route

/system-health

(Replace with the actual route defined in your application.)

HTTP Method

GET

Purpose

Displays the overall operational status of the platform.

The administrator can immediately determine whether all major application components are functioning correctly.

Components Monitored

The health dashboard typically verifies:

- PostgreSQL Database
- Flask Application
- Gemini AI Service
- SMTP Mail Server
- Event Tracking Module
- Campaign Engine
- Risk Engine

Each component is evaluated independently.

Health Status Levels

Every monitored service is assigned one of three possible states.

Status	Meaning
Healthy	Service is functioning normally
Warning	Service is operational but experiencing issues
Critical	Service is unavailable

These status indicators allow administrators to prioritize maintenance activities.

Route 2 – Database Health Check

Purpose

Verifies that the PostgreSQL database is available and responding.

Validation Steps

The system attempts to:

1. Establish a database connection.
2. Execute a simple query.
3. Measure response time.
4. Close the connection.

If all operations succeed, the database is marked as **Healthy**.

If any operation fails, the platform records the failure and displays an appropriate warning.

Information Displayed

Typical database information includes:

- Connection Status
 - Database Name
 - Response Time
 - Last Successful Check
-

Route 3 – AI Service Health

Purpose

Determines whether the Artificial Intelligence Engine is available.

Validation

The platform verifies:

- API configuration.
- AI client initialization.
- Successful communication with Gemini.

If communication fails,

the dashboard displays a warning indicating that AI-generated phishing emails cannot currently be produced.

Route 4 – SMTP Health Check

Purpose

Verifies that the configured mail server is operational.

The system checks:

- SMTP Host
- Authentication
- Connection Availability

If the SMTP server is unavailable,

campaign generation remains possible,

but email delivery is temporarily suspended until connectivity is restored.

Route 5 – Event Tracking Health

Purpose

Ensures that employee interaction logging is functioning correctly.

The platform verifies:

- Event logging service availability.
- Database write capability.
- Event storage integrity.

If event logging becomes unavailable,

the dashboard immediately reports the issue because employee behaviour can no longer be recorded accurately.

Route 6 – Risk Engine Health

Purpose

Verifies that the Risk Assessment Engine is operational.

The platform checks whether:

- Risk calculations complete successfully.
- Employee scores can be updated.
- Department statistics can be generated.

If this component fails,

campaigns may continue,

but employee cybersecurity metrics will not be updated.

Route 7 – Administrative Utility Functions

In addition to health monitoring,

the platform contains several administrative utility functions that support daily system operation.

Typical utilities include:

- Refresh dashboard data.
- Recalculate employee risk.
- Synchronize campaign information.
- Clear temporary cache.
- Refresh system statistics.
- Verify application configuration.

These utilities simplify maintenance by allowing administrators to perform common operational tasks without directly accessing the database.

Platform Diagnostics

The System Health Module provides diagnostic information to assist with troubleshooting.

Typical diagnostic information includes:

- Active database connection.
- Number of active campaigns.
- Number of employees.
- Number of recorded events.
- AI service availability.
- SMTP availability.
- Last successful health check.

This information enables administrators to quickly identify the source of operational issues.

Automatic Health Monitoring

Health monitoring is not limited to manual checks.

The platform periodically evaluates critical services while the application is running.

This enables administrators to detect failures before they interrupt phishing awareness campaigns.

Examples include:

- Database disconnection.
 - SMTP authentication failure.
 - AI service outage.
 - Event logging failure.
 - Campaign engine errors.
-

Error Handling

The System Health Module gracefully handles failures.

Situation	System Response
Database unavailable	Display Critical status
AI service unavailable	Display Warning and disable AI generation
SMTP unavailable	Display Warning and suspend email delivery

Event Logger unavailable	Display Critical status
Risk Engine unavailable	Display Warning and suspend score updates
Unknown error	Record diagnostic information and display generic system warning

This prevents isolated failures from causing a complete application outage.

Security Considerations

The System Health Module follows several security principles.

Administrator Access

Only authenticated administrators may access health monitoring information.

Read-Only Diagnostics

Health routes retrieve operational information without modifying production data.

Controlled Visibility

Sensitive internal configuration values, such as passwords or API keys, are never displayed on the dashboard.

Audit Logging

Important operational failures can be recorded for future investigation and troubleshooting.

Benefits of the System Health Module

The System Health Routes provide several important operational advantages.

- Monitor platform availability.
- Detect infrastructure failures.

- Verify AI service availability.
 - Confirm SMTP connectivity.
 - Monitor database performance.
 - Detect logging failures.
 - Assist administrators during troubleshooting.
 - Improve overall platform reliability.
-

Chapter Summary

The System Health & Administrative Utility Routes provide continuous visibility into the operational status of the AI-Powered Phishing Awareness & Training Platform. By monitoring critical infrastructure components such as the database, AI service, SMTP server, event logging, and risk calculation engine, these routes enable administrators to detect issues early, maintain service availability, and ensure reliable execution of phishing awareness campaigns. They also provide essential administrative utilities that simplify maintenance and improve the long-term stability of the platform.

17. Developer Maintenance Guide

The AI-Powered Phishing Awareness & Training Platform has been developed using a modular architecture to simplify future maintenance and feature enhancement. Every major functionality, including Artificial Intelligence, phishing campaign management, event tracking, risk assessment, dashboard generation, reporting, and security, has been separated into independent modules. This design minimizes the impact of future changes because developers can modify individual components without affecting the rest of the application.

When implementing any modification, developers should first understand the complete workflow of the platform. Every phishing campaign begins with administrator authentication, followed by campaign creation, employee selection, threat scenario selection, AI prompt generation, campaign validation, encrypted storage, email delivery, event tracking, risk calculation, and finally dashboard reporting. Since all modules are interconnected, changes should always be made with consideration for downstream dependencies.

Database modifications should be performed carefully. Any changes to table structures, relationships, or column names must also be reflected in the corresponding SQL queries, data access functions, dashboard components, reporting modules, and risk calculation logic. All database changes should be tested using representative data before deployment to ensure existing functionality remains unaffected.

When introducing new phishing scenarios, developers should add the scenario to the Threat Scenario Library using the existing structure. Every new scenario should include a unique identifier, descriptive title, realistic business context, and

associated payload type. Newly added scenarios should remain relevant to the target department and should not duplicate previously implemented phishing themes.

If additional organizational departments need to be supported, developers should update all dependent components consistently. This includes the employee database, department mappings, threat scenarios, sender identities, AI prompt generation logic, department risk calculations, dashboard analytics, and reporting modules. Maintaining consistency across these modules ensures that the new department behaves identically to existing departments.

Future modifications to the Artificial Intelligence Engine should preserve the adaptive learning capability of the platform. The AI prompt should continue using previous campaign history, subject lines, call-to-action phrases, phishing scenarios, and organizational intelligence to avoid repetitive phishing campaigns. New prompt instructions should improve realism without removing existing safeguards that prevent duplication.

The Campaign Validation Engine should continue acting as the quality assurance layer for AI-generated emails. Any future validation rules should be implemented in a modular manner so that additional similarity checks, business rules, or organizational policies can be introduced without altering the overall campaign workflow.

Changes to the Risk Assessment Engine should be made carefully because risk scores influence dashboards, reports, employee rankings, department analytics, and organizational security metrics. Whenever event weights, department weights, normalization formulas, or classification thresholds are modified, developers should validate the calculations using multiple test cases to ensure consistent and explainable results.

The Event Tracking System should continue recording every employee interaction as an independent event. New interaction types may be added in future versions provided they follow the existing event structure and remain compatible with campaign history, reporting, and risk calculations. Every recorded event should continue to be encrypted before database storage.

Email delivery functionality should preserve personalized communication. Any modifications to templates, HTML formatting, corporate branding, sender identities, signatures, tracking links, or tracking images should maintain compatibility with the Event Tracking System to ensure employee behaviour continues to be monitored accurately.

Dashboard enhancements should remain modular. New widgets should retrieve information through dedicated backend functions rather than embedding business logic inside HTML templates. This separation improves maintainability, simplifies testing, and reduces the impact of future interface changes.

Reporting modules should continue generating information directly from validated database records rather than temporary application variables. This ensures report consistency, repeatability, and auditability. Any newly introduced reports should follow the existing reporting architecture and reuse available business logic whenever possible.

Developers should preserve the platform's layered security architecture during future enhancements. Sensitive information should never be stored in plain text. Campaign history, AI prompts, simulation events, and other confidential

information should continue to be encrypted before storage. Administrator authentication, brute-force protection, session management, and security notifications should remain active in all future releases.

Error handling should remain centralized wherever possible. Every new function should validate input, handle database failures gracefully, record operational errors, and provide meaningful feedback without exposing sensitive system information. Unexpected exceptions should be logged to facilitate debugging while preserving application stability.

The project should continue following consistent coding standards. Function names should clearly describe their purpose, modules should perform only one primary responsibility, duplicate logic should be avoided, and reusable functionality should be implemented through helper functions. Developers should document significant changes within the source code to simplify future maintenance.

Before deploying any modification, comprehensive testing should be performed across all major workflows, including administrator authentication, campaign generation, AI email creation, campaign validation, email delivery, event tracking, risk calculation, dashboard visualization, report generation, and system health monitoring. Regression testing is essential because many modules depend on one another.

Future versions of the platform may incorporate additional capabilities such as Microsoft 365 integration, enterprise identity providers, scheduled phishing campaigns, advanced analytics, machine learning-based risk prediction, SIEM integration, mobile support, and cloud deployment. These enhancements should be developed as independent modules that integrate with the existing architecture rather than replacing core components.

The modular design, layered architecture, centralized business logic, encrypted data storage, adaptive Artificial Intelligence engine, and standardized workflows make the platform highly maintainable and scalable. By following the architectural principles and development practices described throughout this guide, future developers can safely extend the application while preserving its reliability, security, and overall design integrity.

18. Installation and Deployment Guide

The AI-Powered Phishing Awareness & Training Platform has been designed to operate within a standard Python-based environment using Flask as the web framework and PostgreSQL as the backend database. Before installation, developers should ensure that all prerequisite software, including Python, PostgreSQL, Git, and a suitable code editor such as Visual Studio Code, has been installed successfully on the target system.

The project source code should first be copied from the project repository or transferred from the deployment package into the desired working directory. After opening the project folder, all required Python libraries should be installed using the dependency file provided with the project. This ensures that every external package required by the application is available before execution.

A PostgreSQL database should then be created using the name specified in the application configuration. If an existing database backup is available, it should be restored before the application is executed. After successful restoration,

developers should verify that all required tables have been created correctly and that employee records, campaign information, threat scenarios, and other application data are available.

The database connection settings inside the application should then be updated according to the deployment environment. These settings include the database host, database name, username, password, and port number. The application should always be tested using the configured database before deployment to production.

The Artificial Intelligence service should then be configured by providing the appropriate API credentials. Developers should verify that the configured AI service can successfully receive requests and generate phishing email content. Any connectivity issues should be resolved before the platform is made available to administrators.

The email delivery service should also be configured before production deployment. The SMTP server address, authentication credentials, sender email address, and associated security settings should be verified to ensure successful delivery of phishing simulation emails. Developers should perform a test email delivery before executing live phishing campaigns.

When the application is executed for the first time, the platform automatically checks for the existence of the encryption key used to protect sensitive information. If the key does not already exist, the application generates a new encryption key automatically and stores it for future use. This key should be protected carefully because it is required to decrypt encrypted campaign history and employee interaction records.

After configuration has been completed, the Flask application can be started. During startup, the application initializes the database connection, loads the Artificial Intelligence configuration, initializes security services, loads phishing scenarios, prepares supporting modules, and starts the web server. Developers should verify that no initialization errors appear in the application logs before accessing the system.

Once the server is running successfully, the administrator portal can be accessed using the configured application URL through a web browser. The administrator should authenticate using valid credentials before accessing the dashboard. Successful login confirms that database connectivity, session management, and authentication services are functioning correctly.

After administrator authentication, developers should verify the complete operational workflow by creating a test phishing campaign. The campaign should include employee selection, AI-generated email creation, campaign validation, secure storage, email delivery, event tracking, risk calculation, and dashboard updates. Successfully completing this workflow confirms that all major application modules are functioning correctly.

Before production deployment, developers should perform comprehensive validation of all major system components. This includes database operations, Artificial Intelligence communication, SMTP connectivity, event tracking, campaign validation, dashboard visualization, report generation, administrator authentication, brute-force protection, encryption, and risk calculation. Every component should operate correctly before the platform is made available to end users.

For production environments, the application should not be executed using the default Flask development server. Instead, a production-grade application server should be used together with a reverse proxy to improve security, scalability, and performance. Secure communication should be enabled using HTTPS, and appropriate firewall rules should restrict unauthorized network access to application services and the database server.

Regular database backups should be scheduled to protect campaign history, employee records, and organizational cybersecurity data. Backup procedures should be tested periodically to ensure successful recovery in the event of hardware failure or accidental data loss. Application logs should also be monitored regularly to identify operational issues, failed login attempts, email delivery failures, or unexpected application behaviour.

Sensitive configuration values such as database passwords, SMTP credentials, Artificial Intelligence API keys, and encryption keys should never be hardcoded within the application in production environments. Instead, these values should be stored securely using environment variables or dedicated configuration management systems. Access to configuration files should be restricted to authorized administrators only.

Future software updates should follow a structured deployment process. Before applying updates to the production environment, developers should validate all changes within a testing environment that closely matches production. Regression testing should be performed to confirm that existing functionality remains unaffected. Only after successful testing should updates be deployed to production systems.

By following the installation and deployment process described above, developers can ensure that the AI-Powered Phishing Awareness & Training Platform is installed securely, configured correctly, and deployed in a stable manner. Proper deployment practices, secure configuration management, routine backups, and systematic validation collectively ensure reliable long-term operation of the platform while maintaining its security, performance, and maintainability.

19. Troubleshooting and Maintenance Guide

The AI-Powered Phishing Awareness & Training Platform has been designed with a modular architecture and comprehensive error handling to simplify troubleshooting and long-term maintenance. Nevertheless, issues may arise due to incorrect configuration, infrastructure failures, network interruptions, database problems, or external service unavailability. This chapter provides guidance for identifying, diagnosing, and resolving common operational issues while ensuring minimal disruption to platform functionality.

One of the most common issues encountered during deployment is database connectivity failure. This generally occurs because of incorrect database credentials, unavailable database services, incorrect host configuration, firewall restrictions, or network communication problems. When such issues occur, developers should first verify that the PostgreSQL service is running, confirm that the configured database name, username, password, host address, and port number match the deployment environment, and ensure that the required database tables are present. Application logs should be reviewed to identify detailed database connection errors before restarting the application.

Artificial Intelligence service failures may occur because of invalid API credentials, expired authentication tokens, service outages, internet connectivity problems, or exceeded usage limits. If phishing email generation fails, developers should first verify the configured API credentials, confirm internet connectivity, review application logs for returned API error messages, and perform a test request to verify successful communication with the configured AI provider. Once connectivity has been restored, campaign generation should be tested before resuming production operations.

Email delivery failures generally result from incorrect SMTP configuration, invalid authentication credentials, firewall restrictions, or unavailable mail services. Developers should verify the configured SMTP server, sender credentials, security protocol, authentication settings, and network accessibility. Test emails should be successfully delivered before production campaigns are executed. Any repeated delivery failures should be investigated through SMTP server logs and application logs.

If phishing emails are successfully delivered but employee interactions are not recorded, developers should verify that tracking links and tracking images are correctly generated within the HTML email. Tracking routes should be accessible through a web browser, campaign identifiers should be valid, and database write operations should be functioning correctly. Event logging should always be verified before risk calculations are evaluated because the Risk Assessment Engine depends entirely on recorded interaction data.

Risk scores that fail to update generally indicate missing simulation events, interrupted database synchronization, incorrect event processing, or failed execution of the Risk Assessment Engine. Developers should verify that employee interactions are successfully stored inside the simulation event table, confirm that the Risk Engine executes after each recorded event, and ensure that updated employee scores are written back into the employee database. Dashboard values should always be validated against the underlying database to confirm synchronization accuracy.

Dashboard display problems are usually caused by unavailable backend services, missing database records, failed API responses, template rendering errors, or JavaScript execution issues. Developers should verify backend application status, inspect browser developer tools for client-side errors, confirm successful database queries, and review application logs for template rendering failures. If backend services remain operational, dashboard issues can often be isolated to frontend rendering components.

Campaign generation failures may occur if employee information is incomplete, threat scenarios are unavailable, campaign validation repeatedly fails, or Artificial Intelligence services become unavailable. Developers should confirm that employee records contain valid departments and email addresses, verify the availability of threat scenarios for each department, review campaign validation results, and ensure successful communication with the AI engine. Campaign validation logs provide valuable information when generated emails repeatedly fail organizational quality requirements.

Authentication failures may result from incorrect administrator credentials, expired sessions, account lockouts, or brute-force protection mechanisms. Developers should verify administrator credentials, review login attempt records, confirm account lock status, and wait until temporary lock durations expire before attempting additional authentication. If required, failed login counters may be reset through authorized administrative procedures.

Encryption-related issues generally occur if the encryption key has been deleted, corrupted, or replaced after campaign information has already been stored. Since encrypted campaign history depends upon a consistent encryption key, developers should ensure that the original key remains securely stored and protected throughout the lifetime of the application. Replacing an existing encryption key without decrypting previously stored information may prevent historical campaign records from being recovered successfully.

Performance degradation may occur when the volume of employee records, phishing campaigns, simulation events, or reporting data increases significantly. Developers should periodically optimize database indexes, archive historical campaign information when appropriate, review slow database queries, monitor system resource utilization, and optimize frequently executed business logic. Regular maintenance improves overall platform responsiveness and long-term scalability.

Routine maintenance should be performed periodically to maintain reliable platform operation. Developers should monitor application logs, verify database backups, test restoration procedures, review SMTP connectivity, validate Artificial Intelligence service availability, monitor system health indicators, update software dependencies, and review administrator authentication logs. Preventive maintenance significantly reduces operational interruptions and improves long-term system stability.

Software updates should always follow a controlled deployment process. Before introducing new functionality into the production environment, developers should implement changes within a dedicated testing environment, perform functional testing, regression testing, and security validation, and confirm compatibility with existing modules. Only after successful validation should updates be promoted to production systems.

Security maintenance remains an essential operational responsibility throughout the system lifecycle. Database credentials, SMTP credentials, Artificial Intelligence API keys, encryption keys, and administrator accounts should be reviewed regularly to ensure continued security. Sensitive configuration information should never be exposed through application logs, reports, or user interfaces. Security updates for the operating system, Python dependencies, PostgreSQL, and other supporting software should be applied promptly following organizational change management procedures.

Application backups should be performed regularly to protect employee information, campaign history, phishing scenarios, simulation events, and organizational cybersecurity metrics. Backup integrity should be verified through periodic restoration exercises to ensure that disaster recovery procedures remain effective. Both application source code and database backups should be stored securely using appropriate access controls.

Long-term maintainability depends upon preserving the modular design principles established throughout the platform. New functionality should be implemented within dedicated modules whenever possible, business logic should remain separated from presentation components, reusable code should be centralized, and documentation should be updated whenever significant architectural or functional changes are introduced. Maintaining these development principles will simplify future enhancements while preserving system reliability.

By following the troubleshooting procedures and maintenance practices described in this guide, developers and system administrators can efficiently diagnose operational issues, minimize service interruptions, maintain application security, and ensure the continued reliability of the AI-Powered Phishing Awareness & Training Platform throughout its operational lifecycle.

20. Conclusion

The AI-Powered Phishing Awareness & Training Platform has been developed as a comprehensive enterprise cybersecurity awareness solution that combines Artificial Intelligence, phishing simulation, employee behaviour analysis, cybersecurity risk assessment, and administrative monitoring within a single integrated platform. The primary objective of the project is to improve organizational cybersecurity awareness by identifying vulnerable employees, measuring phishing susceptibility, and providing administrators with actionable insights to strengthen organizational security.

Unlike conventional phishing simulation platforms that rely on static email templates, this platform introduces an adaptive Artificial Intelligence-driven approach that continuously evolves phishing campaigns based on previous campaign history, employee behaviour, organizational intelligence, and department-specific attack scenarios. By incorporating historical learning into every new campaign, the system minimizes repetition while maintaining realistic and engaging phishing simulations.

Throughout the platform, each functional component has been designed to perform a dedicated responsibility while remaining fully integrated with the overall system architecture. The Campaign Management Module coordinates phishing campaign creation and execution, the Artificial Intelligence Engine generates realistic phishing emails, the Campaign Validation Engine ensures campaign originality and quality, the Email Delivery System securely distributes personalized phishing simulations, the Event Tracking System records employee behaviour, and the Risk Assessment Engine converts employee interactions into measurable cybersecurity risk indicators. The Administrator Dashboard and Reporting Modules consolidate this information into meaningful analytics that support informed decision-making.

The platform follows a modular software architecture that separates business logic, presentation logic, security mechanisms, and database operations into independent components. This design significantly improves maintainability, scalability, and long-term extensibility. New phishing scenarios, departments, reporting capabilities, dashboard features, and Artificial Intelligence enhancements can be incorporated with minimal impact on existing functionality, allowing the platform to evolve alongside organizational requirements.

Security has been incorporated as a fundamental design principle rather than an additional feature. Sensitive campaign information, employee interaction records, and Artificial Intelligence prompts are encrypted before storage, administrator authentication is protected through brute-force detection and session management, campaign validation ensures the integrity of AI-generated content, and comprehensive audit trails preserve the complete history of every phishing simulation. These controls collectively protect organizational information while maintaining transparency and accountability.

The platform also emphasizes measurable cybersecurity awareness. Rather than simply recording phishing success or failure, the Risk Assessment Engine transforms employee behaviour into standardized numerical scores, risk classifications, rankings, percentiles, and department-level metrics. These quantitative measurements provide administrators with objective evidence that can guide targeted awareness programmes, security policy improvements, and future organizational decision-making.

From a software engineering perspective, the project demonstrates the practical integration of modern Artificial Intelligence with enterprise cybersecurity operations. It combines adaptive prompt engineering, secure software design, centralized campaign management, behavioural analytics, encrypted data processing, modular architecture, and enterprise reporting into a unified platform capable of supporting both operational cybersecurity awareness and long-term organizational resilience.

The documentation presented throughout this Developer Guide has described the complete architecture, workflows, software modules, Artificial Intelligence integration, campaign lifecycle, database interactions, security mechanisms, reporting capabilities, installation procedures, maintenance practices, and troubleshooting guidelines required to understand, operate, maintain, and further develop the platform. It serves as a comprehensive technical reference for future developers, system administrators, researchers, and organizational stakeholders responsible for maintaining or extending the application.

As cyber threats continue to evolve in complexity and sophistication, cybersecurity awareness platforms must also become more adaptive, intelligent, and data-driven. The AI-Powered Phishing Awareness & Training Platform provides a strong foundation for this evolution by combining intelligent automation with measurable security outcomes. Its modular architecture, enterprise-oriented design, and extensible framework position it as a scalable solution capable of supporting future enhancements such as advanced behavioural analytics, predictive risk modelling, enterprise identity integration, cloud deployment, Security Information and Event Management (SIEM) integration, and next-generation cybersecurity awareness technologies.

In conclusion, the AI-Powered Phishing Awareness & Training Platform successfully demonstrates how Artificial Intelligence can be integrated with enterprise phishing simulation to create a secure, scalable, intelligent, and maintainable cybersecurity awareness solution. By combining adaptive phishing generation, comprehensive behavioural tracking, quantitative risk assessment, layered security controls, and centralized administrative management, the platform delivers an effective framework for strengthening organizational cybersecurity awareness while providing future developers with a robust foundation for continued innovation and enhancement.

Appendix

This appendix provides supporting technical information that complements the main Developer Guide. It serves as a quick reference for developers, system administrators, and future maintainers by summarizing important architectural elements, technologies, configuration requirements, and operational standards used throughout the AI-Powered Phishing Awareness & Training Platform.

The platform has been developed using a layered architecture that separates presentation, business logic, data access, Artificial Intelligence, security, and reporting into independent modules. This modular structure simplifies maintenance, testing, debugging, and future feature development while reducing code dependency across components.

The application is implemented using Python as the primary programming language with the Flask framework providing web application functionality. PostgreSQL serves as the primary relational database for storing employee records, campaign information, simulation history, event logs, and cybersecurity risk metrics. HTML, CSS, and JavaScript provide the user interface for administrators, while Google Gemini is integrated to generate adaptive phishing email content. SMTP services are used to deliver phishing simulation emails, and cryptographic libraries provide secure encryption for sensitive organizational information.

The primary software components include the Administrator Authentication Module, Campaign Management Engine, Artificial Intelligence Email Evolution Engine, Campaign Validation Engine, Email Delivery System, Event Tracking System, Risk Assessment Engine, Reporting Module, Dashboard Module, System Health Monitor, and supporting utility services. Each module performs a dedicated responsibility while communicating with other modules through clearly defined interfaces.

The database stores all persistent information required by the platform. Core database entities include employee information, phishing campaign records, campaign participant details, encrypted Artificial Intelligence prompt history, employee interaction events, administrator authentication records, and calculated cybersecurity risk information. Every database operation is performed through controlled application functions to maintain consistency, security, and data integrity.

Artificial Intelligence is integrated into the campaign generation process through structured prompt engineering. Before generating each phishing email, the system analyzes employee history, department, previous campaign performance, historical subject lines, previous call-to-action phrases, organizational intelligence, and phishing scenarios. The generated email is then validated against organizational quality standards before being approved for delivery. This process ensures that phishing campaigns remain adaptive, realistic, and resistant to repetition.

Security has been incorporated throughout the platform using multiple independent protection mechanisms. Sensitive information is encrypted before storage, administrator authentication is protected through brute-force detection and session management, campaign integrity is maintained through unique campaign identifiers, and comprehensive audit trails preserve the complete history of every phishing simulation. These controls collectively protect organizational information while supporting accountability and regulatory compliance.

The platform follows consistent software engineering practices to improve maintainability. Each module has a clearly defined responsibility, reusable functionality is centralized wherever possible, descriptive naming conventions are used throughout the application, and business logic is separated from presentation logic. Future developers are encouraged to preserve these architectural principles when implementing enhancements or modifications.

Configuration values should remain external to application logic whenever possible. Database connection information, SMTP credentials, Artificial Intelligence API credentials, encryption keys, server addresses, and other

environment-specific values should be maintained using secure configuration management rather than embedded directly within source code. This approach simplifies deployment across multiple environments while improving overall security.

Routine operational maintenance includes database backup verification, Artificial Intelligence service validation, SMTP connectivity testing, system health monitoring, dependency updates, application log review, security audit review, and periodic regression testing. Preventive maintenance significantly improves application reliability and reduces operational risk over the lifetime of the platform.

The application has been designed to support future expansion without significant architectural modification. Additional phishing scenarios, organizational departments, dashboard components, reporting capabilities, Artificial Intelligence improvements, machine learning models, enterprise authentication systems, Security Information and Event Management integrations, and cloud deployment capabilities can be incorporated while preserving the existing modular architecture.

The following abbreviations are used throughout this documentation for consistency:

Abbreviation	Meaning
AI	Artificial Intelligence
API	Application Programming Interface
CTA	Call-To-Action
CRUD	Create, Read, Update, Delete
DB	Database
DPI	Digital Public Infrastructure
ER	Entity Relationship
HTML	HyperText Markup Language
HTTP	HyperText Transfer Protocol
JSON	JavaScript Object Notation
MFA	Multi-Factor Authentication
PostgreSQL	Open Source Relational Database Management System
SIEM	Security Information and Event Management
SMTP	Simple Mail Transfer Protocol

SQL	Structured Query Language
UI	User Interface
URL	Uniform Resource Locator

Throughout this documentation, the terms *campaign*, *simulation*, *employee interaction*, *event*, *risk score*, *risk level*, *prompt history*, *tracking*, *department risk*, and *organizational risk* retain the meanings defined within the corresponding chapters and should be interpreted consistently across all modules.

This Developer Guide has been prepared to support long-term software maintenance, operational continuity, and future development of the AI-Powered Phishing Awareness & Training Platform. It provides a complete technical reference describing the architecture, implementation, workflows, security controls, operational procedures, and maintenance practices required for successful deployment and continued evolution of the platform. By following the principles, standards, and processes documented throughout this guide, future developers can confidently maintain, enhance, and extend the system while preserving its security, reliability, scalability, and overall architectural integrity.